PORTAFOLIO DE EVIDENCIAS

NOMBRE DEL ESTUDIANTE	Valencia Hernandez Carlos Eduardo
MATRICULA	04220057
CARRERA	Ingeniería en sistemas computacionales
CORREO ELECTRONICO	choterifa@gmail.com
ASIGNATURA	Pentesting
SEMESTRE	9°
DOCENTE	Dr. Holzen A. Martínez García
CORREO ELECTRONICO	hmartinez@itsprogreso.edu.mx holzen.mg@progreso.tecnm.mx

Índice de Contenido

Índice de Contenido 2
Reglas de comportamiento 3
Parcial 1 Unidad 1: Introducción al pentesting 4
Tarea 1: Informe teórico-histórico-reflexivo acerca del pentesting 5
Tarea 2: Presentación individual acerca de los fundamentos del pentesting 19
Tarea 4: Proyecto colaborativo Plan básico de pentesting 24
Coevaluación final (parcial 1) 45
Autoevaluación final (parcial 1) 46
Experiencias de aprendizaje y comentarios finales (parcial 1) 47
Parcial 2 Unidad 2: Fase de Reconocimiento y Escaneo de Vulnerabilidades 48
Tarea 1: Laboratorio de Inteligencia de Fuentes Abiertas (OSINT) y Reconocimiento Perimetral 49
Tarea 2: Escaneo de vulnerabilidades con OpenVAS sobre Metasploitable 2 60
Tarea 3: Ensayo sobre implicaciones éticas y legales del escaneo 79
Tarea 4: Informe final y presentación profesional Fase de Reconocimiento 94
Coevaluación final (parcial 2) 108
Autoevaluación final (parcial 2) 109
Experiencias de aprendizaje y comentarios finales (parcial 2) 110
Referencias Bibliográficas Consolidadas (APA 7ª Edición) 111

Reglas de comportamiento

Reglas de comportamiento del grupo

DERECHOS DEL ALUMNO:

1. Ser respetado por el maestro y el alumno
2. Participar libremente durante las clases
3. Recibir asesorías en caso de no haber comprendido un tema, o aclarar dudas, dicha asesoría se deberá solicitar con un día de anticipación.
4. Recibir retroalimentación en el momento que decida hacerlo
5. Que se le justifique la inasistencia, siempre y cuando presente la evidencia que justifique la falta.
6. Se le reciban, revisen y regresen los trabajos, proyectos de evaluación, prácticas, tareas y actividades evaluadas.
7. Recibir sus promedios de evaluaciones o después de ser evaluado.

OBLIGACIONES:

1. Respetar a su maestro y a sus compañeros
2. Asistir puntualmente a sus clases programadas.
3. Mantener disciplina en las clases y exposiciones del maestro
4. No ingerir alimentos dentro del aula y horarios de clases
5. Mantener limpio y ordenado el salón de clases
6. Cumplir con actividades, tareas, proyectos, investigaciones individuales y en equipo que se le asignen
7. Evitar el uso de celular o aparatos electrónicos que alteren el orden y disciplina en las clases.
8. Integrar y reportar al maestro cada vez que lo requiera el portafolio de evidencias del módulo, el cual incluya trabajos, tareas, actividades, proyectos, que evidencien las competencias generadas en el desarrollo del módulo.

Dr. Holzen A. Martínez-García
NOMBRE Y FIRMA DEL DOCENTE

NOMBRE Y FIRMA DEL ESTUDIANTE

Parcial 1

Unidad 1: Introducción al pentesting

Tarea 1: Informe teórico-histórico-reflexivo acerca del pentesting

Informe teórico-histórico-reflexivo acerca del pentesting.

Cierre: domingo, 6 de septiembre de 2026, 00:00

Elabora un informe que abarcque la historia, teoría y reflexión acerca del pentesting, tomando como base los casos discutidos en sesión.

Rúbrica:

1. Aspecto teórico (fundamentos) – 20 pts

- Definición clara de Pentesting (5 pts)
- Objetivos y alcances (5 pts)
- Metodologías reconocidas (10 pts)

2. Aspecto histórico (evolución) – 20 pts

- Orígenes del Pentesting (5 pts)
- Evolución de técnicas y herramientas (5 pts)
- Relación con casos reales (10 pts)

3. Aspecto reflexivo (análisis crítico) – 30 pts

- Casos exitosos analizados (5 pts)
- Casos fallidos analizados (5 pts)
- Reflexión sobre lecciones aprendidas (10 pts)
- Propuestas de buenas prácticas (10 pts)

4. Estructura del informe – 15 pts

- Introducción clara (3 pts)
- Desarrollo organizado (4 pts)
- Conclusiones pertinentes (4 pts)
- Bibliografía confiable (4 pts)

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:

Informe teórico-histórico-reflexivo acerca del pentesting.

Fecha de entrega:

6 de septiembre de 2026

Asignatura:

Pentesting

Docente:

Martínez García Holzen Atocha

Alumno:

Valencia Hernández Carlos Eduardo

Carrera:

Ingeniería en sistemas computacionales

Semestre/Grupo:

Noveno/Grupo 1

1. Introducción

Hoy en día, la seguridad informática es uno de los temas más críticos para cualquier empresa o institución. Con la llegada de los servicios en la nube, el trabajo remoto y las aplicaciones web modernas, las redes corporativas ya no están protegidas por un simple perímetro físico. Al mismo tiempo, los ataques cibernéticos se han vuelto mucho más frecuentes y sofisticados: desde grupos organizados que buscan dinero mediante ransomware hasta actores avanzados que intentan robar información confidencial o sabotear operaciones.

Durante mucho tiempo, la respuesta tradicional de las organizaciones fue adoptar una postura netamente defensiva y reactiva: instalar antivirus, colocar cortafuegos (firewalls) y esperar que las alertas avisaran cuando algo saliera mal. Sin embargo, los constantes incidentes de seguridad que vemos en las noticias demuestran que esta estrategia es insuficiente. El defensor tiene que proteger miles de puertos, servidores y usuarios, mientras que al atacante le basta con encontrar un solo error o una mala configuración para comprometer toda la red.

Frente a esta realidad surge la necesidad de la seguridad ofensiva y, de manera concreta, del pentesting o pruebas de penetración. La idea central es muy simple pero contundente: la mejor forma de saber si un sistema es seguro es intentar vulnerarlo de forma autorizada y controlada, pensando y actuando exactamente como lo haría un atacante real antes de que un criminal lo haga.

El objetivo de este informe es analizar a fondo el pentesting desde tres ángulos clave: su fundamentación teórica y metodológica, su evolución histórica y su relación con casos reales de la industria, y finalmente una reflexión crítica sobre los éxitos, fracasos y lecciones que nos dejan estos ejercicios en el mundo real. Con esto se busca entender no solo las herramientas técnicas, sino también el valor estratégico, los límites operativos y las buenas prácticas que deben seguirse para que estas pruebas realmente mejoren la seguridad de los sistemas.

2. Aspecto teórico: fundamentos del pentesting

2.1 Definición clara de pentesting

El test de penetración (pentesting) es un método de evaluación de seguridad en el cual un profesional o equipo especializado simula un ataque real contra una infraestructura tecnológica, red o aplicación, bajo autorización previa y por escrito. Su meta fundamental no es únicamente encontrar fallos teóricos en el software, sino intentar explotarlos de manera controlada para verificar hasta dónde podría llegar un atacante y qué impacto real tendría esa intrusión en la organización.

En la práctica y en los cursos de seguridad, suele existir confusión entre tres actividades que parecen similares pero tienen enfoques y alcances muy distintos:

- **Escaneo de vulnerabilidades:** Es un proceso casi 100% automatizado mediante software (como Nessus u OpenVAS) que rastrea puertos y servicios para detectar fallos conocidos en bases de datos (firmas). Aunque es rápido, genera muchos falsos positivos y no prueba si una falla realmente se puede explotar en el entorno real.
- **Auditoría de cumplimiento:** Es una revisión de tipo administrativo y documental para comprobar si una empresa cumple con normas o leyes específicas (como ISO 27001, PCI-DSS para tarjetas de crédito o GDPR). Funciona como una lista de verificación (checklist) donde se certifica que existen ciertas políticas, pero no se prueba la resistencia técnica real del sistema.
- **Pentesting (prueba de penetración):** Es un ejercicio práctico, manual y analítico. El especialista utiliza herramientas pero sobre todo su propio razonamiento para encadenar fallos menores (exploit chaining), evadir defensas, escalar privilegios en los servidores y demostrar con pruebas fehacientes qué datos o sistemas quedaron expuestos, descartando por completo los falsos positivos.

2.2 Objetivos y alcances

Los objetivos principales de un pentesting son: identificar las vías de acceso que un atacante podría aprovechar, cuantificar el impacto operacional o económico que causaría una intrusión, evaluar la efectividad real de las defensas y de los equipos de monitoreo (Blue Team), y entregar a la dirección técnica recomendaciones claras para solucionar los problemas detectados.

Dependiendo del nivel de información previa que la empresa evaluada entregue a los analistas, el pentesting se clasifica en tres modalidades reconocidas:

- **Caja negra (Black Box):** Los analistas no reciben ninguna información técnica interna, solo el nombre de la empresa o dominios públicos. Simula el punto de vista de un atacante externo desconocido. Requiere una fase muy intensa de recolección de información (OSINT) y escaneo inicial.
- **Caja blanca (White Box):** El equipo de pruebas recibe información completa: diagramas de arquitectura de red, código fuente, documentación de APIs e incluso credenciales con distintos niveles de privilegio. Es ideal cuando se desea una revisión profunda y exhaustiva del sistema.
- **Caja gris (Grey Box):** Es el esquema más habitual en las empresas. Se entrega un acceso limitado, como una cuenta de usuario estándar y nociones básicas de la red. Simula el escenario sumamente común de un empleado interno descontento o de un atacante que ya consiguió engañar a un usuario mediante phishing y busca moverse por la red interna.

Un componente indispensable en cualquier prueba son las **Reglas de Compromiso (Rules of Engagement o RoE)**. Este es el contrato formal y legal que delimita exactamente qué se puede y qué no se puede hacer durante la prueba. En las RoE se definen las direcciones IP autorizadas, los servidores excluidos (para no afectar la operación diaria o servidores de cobro), los horarios permitidos para las pruebas, y los protocolos de aviso inmediato si se descubre una vulnerabilidad extremadamente grave. Sin este documento firmado por la autoridad competente, cualquier intento de intrusión constituye un delito informático.

2.3 Metodologías reconocidas

Para que un pentesting sea profesional, ordenado y repetible, no se trabaja de forma improvisada, sino siguiendo metodologías estándar reconocidas por la industria de ciberseguridad:

- **PTES (Penetration Testing Execution Standard):** Es una de las metodologías más completas del ámbito profesional. Define siete etapas sucesivas: 1) Acuerdos iniciales (Pre-engagement), 2) Recolección de información (Intelligence Gathering), 3) Modelado de amenazas (Threat

Modeling), 4) Análisis de vulnerabilidades, 5) Explotación, 6) Post-explotación (donde se mide el valor de los datos comprometidos y persistencia), y 7) Elaboración del reporte técnico y ejecutivo.

- **NIST SP 800-115:** Desarrollada por el Instituto Nacional de Estándares y Tecnología de EE. UU. Es la guía de referencia técnica para entidades de gobierno y organizaciones que manejan infraestructuras críticas. Organiza las pruebas en cuatro grandes fases: Planificación, Descubrimiento, Ataque y Reporte.
- **OSSTMM (Open Source Security Testing Methodology Manual):** Diseñada por ISECOM, aporta un enfoque científico y métrico. Se enfoca en cuantificar la seguridad operacional calculando Valores de Evaluación de Riesgo (RAV) y analizando cómo interactúan las personas, la infraestructura tecnológica y la seguridad física.
- **OWASP WSTG (Web Security Testing Guide v4.2):** Es el estándar indiscutible para auditar aplicaciones y servicios web. Contiene guías paso a paso organizadas en 12 categorías para probar la autenticación, autorización, gestión de sesiones, validación de datos de entrada, criptografía y errores en la lógica de negocio de las páginas y APIs.

3. Aspecto histórico: evolución del pentesting

3.1 Orígenes del pentesting

El origen del pentesting se remonta a la década de 1960, cuando la expansión de los sistemas de tiempo compartido (time-sharing) hizo evidente que varios usuarios podían acceder simultáneamente a un mismo computador, lo que abrió interrogantes sobre la confidencialidad de la información. En 1967, durante la Joint Computer Conference, especialistas en seguridad debatieron por primera vez de forma pública la necesidad de "penetrar" deliberadamente los sistemas para descubrir sus debilidades antes de que lo hiciera un tercero no autorizado.

A partir de esa discusión, el Departamento de Defensa de los Estados Unidos, la Fuerza Aérea, la NSA y la RAND Corporation impulsaron la creación de los llamados "tiger teams": grupos formados por especialistas que intentaban comprometer sistemas gubernamentales y militares bajo autorización explícita. Paralelamente, en 1970, Willis H. Ware coordinó para la RAND Corporation el informe Security Controls for Computer Systems, donde se alertó formalmente sobre la fragilidad de los enlaces

remotos. En 1971 la Fuerza Aérea de EE. UU. ordenó pruebas de seguridad sobre sistemas de tiempo compartido, y en 1974 se realizó una de las evaluaciones más citadas de esta etapa: la prueba de penetración al sistema operativo MULTICS, que reveló fallas críticas de seguridad y sirvió de base para investigaciones posteriores sobre arquitecturas de referencia seguras.

Un hito fundamental ocurrió en 1972, cuando James P. Anderson publicó un reporte técnico que proporcionó lineamientos paso a paso para los Tiger Teams, estableciendo las bases metodológicas del pentesting moderno. Los pasos formalizados por Anderson fueron:

1. Encontrar una vulnerabilidad explotable.
2. Diseñar un ataque alrededor de ella.
3. Probar el ataque en un entorno controlado.
4. Aprovechar una línea en uso para operaciones ACS (acceso al canal del sistema).
5. Introducir el ataque en el objetivo.
6. Explotar la entrada para la recuperación o modificación de información clasificada.

Poco después, en 1973, el Departamento de Defensa formalizó la primera metodología de prueba denominada FMH (Flaw Hypothesis Methodology), estructurando el proceso de plantear hipótesis sobre fallos lógicos, verificarlos de forma activa y documentar el impacto para su corrección.

3.2 Evolución de técnicas y herramientas

Durante los años 80 y 90, con la masificación de las redes corporativas e Internet, el pentesting pasó de ser una práctica exclusivamente militar a una necesidad del sector privado. Es en esta etapa cuando el término "hacking ético" comienza a popularizarse para distinguir la actividad autorizada de la intrusión maliciosa. En sus comienzos, las pruebas requerían técnicas manuales de phreaking y war dialing mediante software como ToneLoc para discar miles de teléfonos buscando módems corporativos desprotegidos, además de scripts en C y Perl desarrollados de forma artesanal.

Hacia finales de los 90, las técnicas manuales dieron paso a herramientas especializadas: SATAN (1995) fue el primer escáner que generó debate público sobre la detección remota; Nmap (creado en 1997 por

Fyodor) revolucionó el escaneo de puertos y el reconocimiento de sistemas operativos, y Nessus (1998) automatizó el rastreo de vulnerabilidades en servicios de red.

A mediados de los 2000 surgieron frameworks integrales como Metasploit (2003), que unificó la explotación de vulnerabilidades conocidas en una plataforma modular y extensible, cambiando para siempre el trabajo de los analistas. En el ámbito de las aplicaciones web, la aparición de Burp Suite y OWASP ZAP facilitó la interceptación y manipulación de tráfico HTTP, mientras que la publicación periódica del OWASP Top 10 (desde 2003) estandarizó el lenguaje sobre los riesgos más comunes en el software.

En la década de 2010, la sofisticación de las amenazas avanzadas persistentes (APT) impulsó la aparición de plataformas de simulación de adversarios como Cobalt Strike, Mythic o Sliver, orientadas no solo a encontrar vulnerabilidades técnicas aisladas sino a emular cadenas completas de ataque (kill chain), incluyendo movimientos laterales y persistencia silenciosa. Más recientemente, la disciplina ha incorporado automatización basada en inteligencia artificial para priorizar hallazgos y correlacionar información de reconocimiento a gran escala (OSINT), a la par del auge del pentesting como servicio (PTaaS) y de los programas de recompensas por vulnerabilidades (Bug Bounty), que amplían la superficie de escrutinio con comunidades globales de investigadores.

3.3 Relación con casos reales

La evolución del pentesting no puede desligarse de los incidentes reales que han demostrado, en la práctica, tanto el valor de las pruebas de penetración como las graves consecuencias de omitirlas o aplicarlas de forma superficial:

- **Brecha de Target (2013):** Atacantes ingresaron a la red corporativa a través de credenciales robadas a un proveedor de climatización (Fazio Mechanical) que tenía acceso remoto. Debido a una deficiente segmentación de red interna, los atacantes se movieron lateralmente hasta alcanzar los terminales punto de venta (POS) y robar datos de más de 40 millones de tarjetas de pago. Este caso evidenció la importancia de evaluar la seguridad de terceros dentro del alcance de cualquier pentest.
- **Brecha de Equifax (2017):** La explotación de una vulnerabilidad conocida en Apache Struts (CVE-2017-5638), para la cual ya existía parche oficial disponible meses antes, expuso datos personales

y financieros de 147 millones de personas. El caso ilustra que detectar una falla técnica o recibir un reporte no basta si la organización no tiene un proceso ágil para gestionar su remediación.

- **Brecha de Capital One (2019):** Una atacante explotó una mala configuración en un firewall de aplicación web (WAF) alojado en Amazon Web Services (AWS) mediante una vulnerabilidad SSRF (Server-Side Request Forgery). A través de esto accedió a los metadatos de la nube y robó datos de más de 100 millones de clientes, mostrando los riesgos específicos de las arquitecturas cloud y la necesidad de auditar permisos IAM.
- **Brecha de Uber (2022):** Un atacante obtuvo acceso a los sistemas internos de la empresa mediante técnicas de ingeniería social y fatiga de autenticación multifactor (MFA fatigue) dirigida a un empleado externo contratista. Una vez dentro de la intranet, encontró credenciales administrativas en scripts compartidos. Esto demostró que las pruebas de penetración deben incorporar de forma sistemática vectores humanos y no limitarse a lo puramente tecnológico.
- **Colonial Pipeline (2021):** El compromiso de una contraseña filtrada de una cuenta de VPN que no tenía autenticación multifactor provocó la paralización del mayor gasoducto de combustibles de la costa este de EE. UU., subrayando la enorme relevancia del pentesting en sectores de infraestructura crítica.
- **Caso SolarWinds (2020):** La inserción de código malicioso en las actualizaciones oficiales de la plataforma Orion demostró el peligro de los ataques a la cadena de suministro de software (SUNBURST), dejando claro que los pentests modernos deben auditar también los pipelines de desarrollo e integración continua (CI/CD).

4. Aspecto reflexivo: análisis crítico

4.1 Casos exitosos analizados

Entre los ejemplos que demuestran el valor del pentesting bien ejecutado se encuentran los programas de Bug Bounty de compañías como Google, Microsoft o el propio Departamento de Defensa de EE. UU. (con iniciativas como 'Hack the Pentagon'). En estos esquemas, investigadores externos identifican y reportan de forma responsable fallos críticos antes de que puedan ser explotados maliciosamente, permitiendo a los equipos de desarrollo corregirlos oportunamente.

De igual manera, los ejercicios de Red Teaming en el sector bancario alineados a marcos como TIBER-EU han demostrado una alta efectividad para exponer brechas en la capacidad de detección y respuesta de los equipos internos. Al simular atacantes reales, estos ejercicios suelen descubrir configuraciones erróneas críticas en Active Directory (como delegaciones Kerberos indebidas o elevación de privilegios locales) que los escáneres automáticos pasan por alto por completo.

El éxito de estos casos tiene en común un único elemento esencial: la madurez en el proceso organizacional. Esto implica contar con un alcance bien definido, un seguimiento formal de los hallazgos, la asignación de responsables técnicos para la remediación y la repetición periódica de las pruebas para verificar que las brechas fueron efectivamente solucionadas.

4.2 Casos fallidos analizados

En contraste, casos como el de Equifax muestran que la existencia de hallazgos de seguridad no garantiza protección si la organización carece de un proceso eficaz de gestión de parches e inventario de activos. La empresa realizaba auditorías periódicas, pero el reporte técnico quedó archivado sin aplicarse en los servidores productivos correctos.

De forma análoga, incidentes como el de Uber en 2022 o su fuga de datos de 2016 (donde credenciales de AWS estaban expuestas en repositorios privados de GitHub) evidenciaron que muchas organizaciones concentran sus pruebas exclusivamente en la infraestructura perimetral oficial y descuidan el factor humano y los entornos de desarrollo, a pesar de que la ingeniería social continúa siendo el vector de compromiso inicial más efectivo.

Asimismo, en el plano operativo se han documentado casos donde pruebas de penetración mal planificadas o sin reglas de compromiso claras causaron la caída involuntaria de servidores de producción o el bloqueo de autómatas programables (PLCs) en redes industriales y sistemas SCADA, demostrando que un pentest sin la debida calibración puede causar el mismo daño que intenta prevenir.

4.3 Reflexión sobre lecciones aprendidas

Al investigar los casos exitosos y fallidos se desprenden lecciones muy concretas sobre las limitaciones del modelo tradicional de seguridad:

- **El pentesting es una fotografía puntual:** Representa el estado de seguridad en una fecha y hora específicas. En empresas modernas que actualizan código y despliegan servicios varias veces por semana, el valor de un informe anual se diluye con rapidez si no se complementa con evaluaciones continuas.
- **La trampa del cumplimiento de papel:** Realizar pruebas únicamente para obtener un sello de certificación reglamentario genera una falsa sensación de seguridad. Las organizaciones suelen limitar artificialmente el alcance de la prueba para 'aprobar la auditoría', dejando fuera los sistemas más expuestos.
- **La remediación es tan importante como la detección:** Descubrir cien fallas no mejora la seguridad de la empresa si el equipo técnico no cuenta con el tiempo, los recursos o el conocimiento necesario para solucionarlas. Un pentesting exitoso termina con los parches aplicados, no con la entrega del documento PDF.
- **El factor humano no se puede omitir:** Ningún firewall o sistema de cifrado detiene a un atacante que engaña a un empleado mediante vishing o fatiga de notificaciones push. La seguridad técnica debe complementarse siempre con programas de concientización y pruebas controladas de ingeniería social.

4.4 Propuestas de buenas prácticas

Para superar estas deficiencias y lograr que las pruebas ofensivas aporten valor real, se proponen las siguientes buenas prácticas para las organizaciones actuales:

- **Adoptar ejercicios de Purple Teaming:** Fomentar que el equipo ofensivo (Red Team) y el defensivo (Blue Team) trabajen juntos en tiempo real durante la prueba. Esto permite a los defensores ajustar sus reglas en el SIEM o antivirus inmediatamente después de que un ataque es probado.
- **Integración continua en DevSecOps (Shift-Left):** Incorporar pruebas automatizadas de código (SAST y DAST) en las fases iniciales del ciclo de desarrollo. Esto soluciona los errores básicos de forma temprana y permite que los analistas humanos se concentren en buscar fallas complejas de lógica en el pentest final.

- **Enfoque de pruebas guiadas por inteligencia de amenazas (TLPT):** Diseñar los ejercicios ofensivos basándose en amenazas reales documentadas que atacan específicamente al sector de la empresa, como lo exige el marco TIBER-EU para instituciones bancarias.
- **Gestión de vulnerabilidades por riesgo real (RBVM):** Priorizar la solución de fallas considerando la probabilidad de explotación real (métricas como EPSS y el catálogo de exploits conocidos de CISA) en lugar de guiarse únicamente por el puntaje numérico del CVSS.
- **Definición exhaustiva de Reglas de Compromiso (RoE):** Establecer límites claros, contactos de emergencia y salvaguardas operativas para proteger la estabilidad de los servicios en producción.

5. Conclusiones

A través de este informe se ha examinado cómo el pentesting ha dejado de ser una actividad puramente experimental de laboratorios militares para convertirse en un componente indispensable de la ingeniería de sistemas moderna. La historia de los primeros Tiger Teams en los años 70 y la evolución de herramientas como Nmap, Metasploit y las modernas plataformas de emulación de adversarios muestran que la disciplina ha evolucionado al mismo ritmo acelerado que la tecnología y los métodos de los atacantes.

Sin embargo, la principal conclusión que se extrae de los incidentes reales analizados es que la efectividad del pentesting no depende de la sofisticación de las herramientas empleadas, sino de la madurez operativa de la organización. Casos como Target, Equifax o Uber confirman que una prueba técnica aislada no previene incidentes si no existe un compromiso real para corregir los hallazgos, si se excluyen partes críticas de la infraestructura o si se ignora el comportamiento humano.

En definitiva, el pentesting no debe verse como un trámite para aprobar una auditoría, sino como un proceso de aprendizaje continuo. Cuando se combina con enfoques colaborativos como Purple Teaming y se integra en el desarrollo ágil mediante DevSecOps, el hacking ético se convierte en la mejor herramienta con la que cuentan los profesionales de sistemas para anticiparse a los incidentes y construir sistemas verdaderamente confiables y resilientes.

6. Referencias

Anderson, J. P. (1972). *Computer security technology planning study* (Technical Report ESD-TR-73-51, Vol. I & II). Electronic Systems Division, Air Force Systems Command, United States Air Force. https://apps.dtic.mil/sti/citations/AD0758206

Herzog, P. (2010). *OSSTMM 3: The Open Source Security Testing Methodology Manual*. Institute for Security and Open Methodologies (ISECOM). https://www.isecom.org/OSSTMM.3.pdf

McGraw, G. (2006). *Software security: Building security in*. Addison-Wesley Professional.

MITRE Corporation. (2023). *MITRE ATT&CK® Enterprise Matrix (v13)*. https://attack.mitre.org/

OWASP Foundation. (2020). *Web Security Testing Guide (WSTG) - Version 4.2*. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/

Penetration Testing Execution Standard Team. (2014). *The Penetration Testing Execution Standard (PTES)*. http://www.pentest-standard.org/

Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-115

Schneier, B. (2000). *Secrets and lies: Digital security in a networked world*. John Wiley & Sons.

Ware, W. H. (1970). *Security controls for computer systems: Report of Defense Science Board Task Force on Computer Security* (Report R-609-1). RAND Corporation. https://www.rand.org/pubs/reports/R609-1.html

Tarea 2: Presentación individual acerca de los fundamentos del pentesting

Presentación individual acerca de los fundamentos del pentesting.

Cierre: martes, 8 de septiembre de 2026, 00:00

Instrucciones para la presentación individual

1. Cada estudiante realizará una **presentación oral individual** en video (10–12 minutos).
2. El tema será **"Fundamentos del Pentesting"**, abarcando:
    - Definición de pentesting.
    - Objetivos y alcances.
    - Principales fases (reconocimiento, escaneo, explotación, post-explotación, reporte).
    - Herramientas básicas.
    - Importancia ética y legal.
3. El material de apoyo (diapositivas o póster digital) debe:
    - Contener esquemas, gráficos o ejemplos claros.
    - Ser breve (no saturar texto).
    - Incluir fuentes de información confiables.
4. El estudiante debe hablar con claridad, seguridad y buena organización del tiempo.
5. Se evaluará tanto el **contenido** como la **forma de exposición**.

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:

Presentación individual acerca de los fundamentos del pentesting.

Fecha de entrega:

8 de septiembre de 2026

Asignatura:

Pentesting

Docente:

Martínez García Holzen Atocha

Alumno:

Valencia Hernández Carlos Eduardo

Carrera:

Ingeniería en sistemas computacionales

Semestre/Grupo:

Noveno/Grupo 1

Enlaces de Evidencia en Línea

Enlace al video de la presentación individual (SharePoint Institucional):
https://itprogreso-my.sharepoint.com/:v:/g/personal/l04220057_progreso_tecnm_mx/IQCJ2so49zF3S4T8m-wlsYxZAYJGFJF6XyJpHzw7mEO5Eno?e=dLuxYT

Enlace a la presentación interactiva en Canva Pro:
https://www.canva.com/d/yGDkFvV7g7el5Cf
(Vista previa directa: https://www.canva.com/d/HwH8bdltLLZ5Wp7)

Estructura Temática de Diapositivas y Guion Oral (11 min 30 s)

• Diapositiva 1: Portada y Presentación (0:00 - 0:40):
Bienvenida institucional, datos del expositor Carlos Eduardo Valencia Hernández y objetivo de la presentación.

• Diapositiva 2: ¿Qué es el Pentesting? (0:40 - 1:25):
Definición formal de prueba de penetración, simulación controlada y la autorización previa como frontera ética y legal.

• Diapositiva 3: Escaneo vs Auditoría vs Pentesting (1:25 - 2:15):
Diferencias críticas de enfoque: escaneo automatizado por firmas, auditoría documental de cumplimiento (ISO 27001) y pentesting analítico manual.

• Diapositiva 4: Objetivos Estratégicos (2:15 - 3:00):
Prevención de brechas, dimensionamiento del riesgo real en el negocio, validación de controles defensivos (Blue Team) y planes de remediación priorizados.

• Diapositiva 5: Alcance y Reglas de Compromiso (RoE) (3:00 - 3:45):
Delimitación de activos permitidos y prohibidos, horarios autorizados, salvaguardas operativas y prohibición de ataques DoS.

• Diapositiva 6: Tipos de Pruebas (3:45 - 4:30):
Modalidades de evaluación: Caja Negra (simulación de atacante externo anónimo), Caja Gris (usuario común o cliente) y Caja Blanca (acceso total a código y arquitectura).

• Diapositiva 7: El Ciclo de Vida del Pentesting (4:30 - 5:15):
Metodología estándar de 5 fases continuas: Reconocimiento, Escaneo, Explotación, Post-Explotación y Reporte formal.

• Diapositiva 8: Fases 1 y 2: Reconocimiento y Escaneo (5:15 - 6:05):
Inteligencia OSINT en fuentes abiertas, mapeo de puertos y servicios con Nmap y detección de vulnerabilidades conocidas (CVEs).

• Diapositiva 9: Fases 3 y 4: Explotación y Post-Explotación (6:05 - 7:00):
Validación práctica del exploit inicial, elevación de privilegios en el sistema objetivo, movimiento lateral y comprobación de persistencia.

• Diapositiva 10: Fase 5: Reporte Ejecutivo y Técnico (7:00 - 7:45):
Estructura del entregable: resumen ejecutivo en lenguaje financiero/negocio y reporte técnico detallado con PoC y parches para administradores.

• Diapositiva 11: Arsenal de Herramientas Básicas (7:45 - 8:35):
Nmap (redes), Wireshark (análisis de tráfico), Burp Suite (seguridad web), Metasploit Framework (explotación) y herramientas de contraseñas (John the Ripper / Hashcat).

• Diapositiva 12: Importancia Ética y Marco Legal (8:35 - 9:25):
El consentimiento informado por escrito, acuerdos de confidencialidad (NDA) y tipificación de delitos informáticos en el Código Penal Federal mexicano (Art. 211 bis).

• Diapositiva 13: Casos Reales y Lecciones de la Industria (9:25 - 10:10):
Análisis de incidentes: el caso Target (movimiento lateral por proveedor externo) y Capital One (mala configuración en AWS).

• Diapositiva 14: Conclusiones y Resiliencia (10:10 - 10:55):
Evolución de la defensa reactiva a la seguridad proactiva, cultura de mejora continua e integración en DevSecOps.

• Diapositiva 15: Referencias Confiables y Despedida (10:55 - 11:30):
Alineación a los estándares internacionales NIST SP 800-115, PTES, OWASP WSTG y Código Penal Federal.

Tarea 4: Proyecto colaborativo Plan básico de pentesting

Video - Entrevistas a empresarios.

Cierre: jueves, 10 de septiembre de 2026, 23:59

- **Objetivo de la tarea**: Elaborar un **video individual o en equipo de máximo 3 personas** (video de 5–8 minutos) en el que se presenten entrevistas a empresarios o responsables de TI sobre su percepción, experiencia y necesidades respecto al **Pentesting** y la **ciberseguridad**.
- **Pasos a seguir**:
  - **Diseño de preguntas**: Elaborar un guion breve con **5 a 8 preguntas relevantes**, por ejemplo:
    - ¿Qué tan importante considera la ciberseguridad en su empresa?
    - ¿Ha escuchado hablar del pentesting? ¿Cómo lo entiende?
    - ¿Ha aplicado alguna vez un servicio de pentesting o pruebas de seguridad?
    - ¿Qué beneficios o limitaciones percibe en su aplicación?
    - ¿Qué retos cree que enfrentan las empresas al implementar pruebas de seguridad?
  - **Selección de entrevistados**: Empresarios, gerentes de sistemas, encargados de TI, consultores o dueños de negocios locales.
  - **Grabación del video**:
    - Presentar brevemente el propósito de la entrevista.
    - Realizar las preguntas de manera clara.
    - Cuidar la calidad de audio e imagen (no es necesario ser profesional, pero sí entendible).
  - **Edición básica**: Agregar título inicial (nombre del proyecto) y créditos finales (participantes).
- **Entrega**:
  - Formato de video (MP4 HD recomendado)

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:

Proyecto colaborativo: Plan básico de pentesting.

Fecha de entrega:

14 de septiembre de 2026

Asignatura:

Pentesting

Docente:

Martínez García Holzen Atocha

Alumno(s):

Valencia Hernández Carlos Eduardo

Canul Canul Osvaldo

Carrera:

Ingeniería en sistemas computacionales

Semestre/Grupo:

Noveno/Grupo 1

1. Introducción

El presente documento técnico y metodológico tiene como propósito formalizar el diseño integral de un plan básico de prueba de penetración (pentesting) concebido específicamente para la organización "Farmacias del Mayab S.A. de C.V.", empresa de referencia en el sector farmacéutico y de distribución médica en el sureste de México, con sede central en Progreso y Mérida, Yucatán. La organización opera actualmente una red comercial de 45 sucursales físicas y ha consolidado una fuerte presencia digital a través de su plataforma omnicanal "MediMayab", la cual integra una aplicación web de comercio electrónico, un módulo de validación de recetas médicas electrónicas y una API REST que gestiona inventarios en tiempo real, cobros y facturación fiscal para miles de clientes. Ante el incremento del volumen transaccional y la digitalización de tratamientos médicos, la Dirección de Tecnologías de la Información de Farmacias del Mayab ha solicitado el diseño formal de este plan para evaluar de forma ordenada, ética y controlada la postura de seguridad de su infraestructura digital expuesta.

Es fundamental puntualizar que este instrumento no representa la ejecución material de los ciberataques, sino la etapa estratégica de planeación previa. En la disciplina de la seguridad ofensiva, la planeación formal constituye más del 70% del éxito de cualquier auditoría: realizar una prueba de penetración sin un alcance nítidamente acotado, sin reglas de compromiso estrictas, sin una delimitación temporal consensuada y sin roles autorizados transforma un ejercicio profesional en una actividad de alto riesgo operativo que puede desembocar en la caída no deseada de los servidores de venta, la corrupción de registros médicos o la incurrencia involuntaria en delitos informáticos conforme al marco normativo vigente.

En el contexto actual, la ciberseguridad se ha consolidado como un requisito vital para cualquier organización que gestione transacciones digitales y datos personales. Para Farmacias del Mayab, la materialización de un incidente de seguridad trasciende las pérdidas económicas inmediatas: implica el riesgo inminente de exfiltración de datos de salud altamente sensibles (diagnósticos clínicos y tratamientos farmacológicos), catalogados como datos especialmente protegidos por la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y la Norma Oficial Mexicana NOM-024-SSA3-2012, además del compromiso de información bancaria sujeta a rigurosas sanciones financieras y normativas bajo los estándares internacionales de PCI-DSS.

El pentesting se erige como la metodología más contundente para anticiparse a estos riesgos, permitiendo que la organización abandone la postura defensiva tradicional netamente reactiva —que suele depender de alarmas y registros posteriores al ataque— para adoptar una postura de resiliencia proactiva. Al simular metódicamente el comportamiento y las tácticas de un atacante real antes de que un cibercriminal explote las brechas existentes, la alta dirección podrá dimensionar con exactitud el impacto práctico de sus vulnerabilidades, priorizar las inversiones de corrección tecnológica y salvaguardar la confianza de sus pacientes en Yucatán.

2. Alcance del Pentesting

Objetivo general

Evaluar la postura de seguridad y el nivel de resiliencia de la infraestructura digital de Farmacias del Mayab S.A. de C.V. mediante la formulación y ejecución simulada de una prueba de penetración en modalidad de Caja Gris, fundamentada en la metodología OWASP Web Security Testing Guide (WSTG v4.2) y el OWASP API Security Top 10, con el propósito de identificar, validar y clasificar vulnerabilidades explotables que puedan comprometer la confidencialidad de los datos clínicos de los pacientes, la integridad de las transacciones financieras o la disponibilidad de la plataforma MediMayab.

Objetivos específicos

- **Identificar fallas de inyección:** Detectar inyecciones SQL, NoSQL y manipulación de comandos en parámetros de búsqueda del catálogo y filtros de existencias de medicamentos.
- **Auditar controles de acceso (BOLA y BFLA):** Verificar si usuarios de perfil cliente o cajero pueden alterar identificadores en la API para acceder a recetas médicas ajenas o funciones de administración.
- **Evaluar autenticación y sesiones:** Examinar la robustez de las sesiones basadas en JSON Web Tokens (JWT), resistencia a ataques de fuerza bruta y políticas de expiración de credenciales.
- **Verificar controles criptográficos:** Comprobar la configuración adecuada de TLS 1.3, algoritmos de cifrado simétrico y el resguardo de datos sensibles de tarjetas bancarias.
- **Auditar la subida de recetas médicas:** Validar que el módulo de carga de recetas impida la subida y ejecución de código malicioso (webshells) en el servidor de almacenamiento.
- **Revisar configuraciones del servidor:** Identificar cabeceras HTTP faltantes (HSTS, CSP), servicios expuestos innecesariamente y librerías desactualizadas con vulnerabilidades conocidas (CVEs).
- **Generar plan de remediación:** Entregar un reporte técnico y ejecutivo clasificado mediante CVSS v3.1 con recomendaciones prácticas para la corrección priorizada de los hallazgos.

Objetivos (Target URLs y Endpoints)

Las pruebas se concentrarán exclusivamente sobre los tres componentes centrales expuestos del cliente:

- **https://tienda.farmaciasdelmayab.com.mx:** Aplicación web principal para clientes finales. Incluye catálogo, carrito de compras, registro, login, pasarela de pago y carga de recetas médicas.

- **https://api.farmaciasdelmayab.com.mx/v2:** Interfaz de programación (API REST) que sirve como núcleo de datos para la tienda web, las terminales de punto de venta (POS) y la futura app móvil.
- **https://pos-web.farmaciasdelmayab.com.mx:** Portal web ligero para operadores de farmacia y cajeros de sucursal, empleado para consultar recetas y validar entregas locales.

Roles para probar

1. **Usuario no autenticado (Unauthenticated / Público):** Simula un atacante anónimo de internet sin credenciales que explora rutas públicas, catálogo y formularios de registro e inicio de sesión.
2. **Paciente / Cliente registrado (Standard Customer):** Simula a un cliente legítimo que realiza pedidos, consulta su historial, sube recetas médicas y administra sus tarjetas guardadas.
3. **Operador de Farmacia / Cajero de Sucursal (Branch Operator):** Simula a un empleado de sucursal con permisos para validar recetas, verificar existencias locales y autorizar despachos.
4. **Administrador de Sistemas (System Admin):** Perfil con privilegios elevados para configuración global, catálogo de precios, gestión de usuarios y generación de reportes financieros.

Áreas incluidas (In-Scope)

- **Módulos de autenticación:** Registro de usuarios, inicio de sesión, recuperación de contraseña, generación y validación de tokens JWT.
- **Comercio electrónico:** Gestión de carrito de compras, cálculo de promociones, aplicación de cupones y checkout.
- **Carga de documentos:** Mecanismos de validación de extensiones y tipos MIME en el módulo de recetas médicas.
- **Endpoints de la API REST v2:** Rutas CRUD de productos, recetas, inventarios, pedidos y perfiles de usuario.
- **Configuración de servidores web:** Servidor Nginx, políticas de CORS, cabeceras HTTP de seguridad y cookies.

Áreas excluidas (Out-of-Scope)

- **Infraestructura física:** Las 45 sucursales, almacenes, oficinas corporativas y centros de distribución.
- **Servicios de pasarelas de pago de terceros:** Servidores externos propiedad de proveedores bancarios (ej. Openpay, Stripe).
- **Consola de administración cloud:** Consolas de gestión de infraestructura de AWS/Azure que no pertenezcan al aplicativo.
- **Pruebas de ingeniería social:** Ataques de phishing, vishing o engaño dirigidos a los empleados o farmacéuticos.
- **Ataques de denegación de servicio (DoS/DDoS):** Queda prohibido saturar el ancho de banda o agotar la memoria de los servidores.
- **Modificación destructiva de datos de producción:** No se alterarán inventarios reales ni bases de datos de clientes reales.

Áreas de prueba según OWASP Top 10 y OWASP API Security Top 10

- **A01:2025 / API1:2023 – Broken Object Level Authorization (BOLA / IDOR):** Verificación de manipulación de IDs en endpoints `/api/v2/recetas/{id}` para consultar expedientes de terceros.

- **A02:2025 – Security Misconfiguration:** Detección de errores detallados, modo debug activo, cabeceras faltantes y puertos innecesarios.
- **A03:2025 / API3:2023 – Broken Object Property Level Authorization:** Validación de asignación masiva de campos protegidos (ej. modificar precios unitarios o roles en JSON).
- **A04:2025 – Cryptographic Failures:** Identificación de algoritmos criptográficos obsoletos y transmisión insegura de credenciales o tokens.
- **A05:2025 – Injection:** Inyecciones SQL en filtros de búsqueda del catálogo e inyección de comandos en rutinas de facturación.
- **A06:2025 – Insecure Design & File Upload Flaws:** Verificación de almacenamiento aislado y validación estricta al subir recetas médicas.
- **A07:2025 / API2:2023 – Broken Authentication:** Evaluación de ataques de fuerza bruta en logins, debilidad en firmas JWT y falta de expiración.
- **A08:2025 / API5:2023 – Broken Function Level Authorization (BFLA):** Comprobación de que clientes o cajeros no puedan invocar rutas administrativas de la API.
- **A09:2025 – Security Logging and Alerting Failures:** Revisión de registros de auditoría y generación de alertas ante múltiples accesos fallidos.
- **A10:2025 / API4:2023 – Lack of Rate Limiting:** Validación de mecanismos de límite de tasa para prevenir enumeración automatizada y abuso de cupones.

Arsenal de herramientas y justificación técnica

- **Burp Suite Professional:** Herramienta insignia para interceptación y manipulación de tráfico HTTP/S, escaneo activo y análisis de lógica de negocio.
- **Postman / Newman:** Plataforma de pruebas para APIs REST, automatización de payloads JSON y validación de Bearer tokens.
- **Nmap:** Mapeo de puertos, identificación de servicios de red y descubrimiento de versiones del servidor web.

- **SQLMap:** Detección y comprobación controlada de inyecciones SQL en parámetros vulnerables previamente localizados.
- **OWASP ZAP:** Escáner complementario para validación de alertas pasivas y activas en el entorno web.
- **ffuf (Fast Web Fuzzer):** Fuzzing de alto rendimiento para descubrimiento de rutas ocultas, archivos residuales y parámetros en la API.
- **jwt_tool:** Suite para auditoría de seguridad sobre tokens JSON Web Token, validación de firmas y manipulación de claims.
- **Browser DevTools:** Inspección de almacenamiento local, almacenamiento de sesión, atributos de cookies y cabeceras de respuesta.

3. Tipos de prueba

Análisis comparativo de los tres enfoques (Caja Negra, Blanca y Gris)

En la disciplina de las pruebas de penetración, la modalidad de evaluación se determina en función del volumen de información técnica previa y el grado de acceso que la empresa evaluada otorga al equipo auditor. Los estándares internacionales reconocen tres enfoques metodológicos:

- **Caja Negra (Black Box):** El equipo evaluador no recibe ninguna información técnica interna de la plataforma; únicamente se le suministran los dominios públicos. Simula el punto de vista de un atacante externo anónimo sin privilegios previos. Su fortaleza es el realismo operativo; no obstante, presenta una baja eficiencia en tiempo, ya que consume gran parte del presupuesto en recolección pasiva (OSINT) y escaneos a ciegas, limitando la profundidad del análisis de la lógica de negocio.
- **Caja Blanca (White Box):** El equipo evaluador cuenta con visibilidad y acceso absoluto: código fuente de la aplicación, diagramas de arquitectura de red, credenciales de administración y documentación de bases de datos. Ofrece una cobertura técnica exhaustiva; sin embargo, tiene un costo económico muy alto, requiere tiempos extensos y se aleja de la perspectiva real de un atacante del mundo exterior.
- **Caja Gris (Grey Box):** Es el esquema más eficiente y representativo en la industria. El cliente entrega información técnica parcial y relevante (documentación de endpoints de la API y credenciales de usuario con distintos niveles de privilegio), pero sin revelar el código fuente ni la red interna. Simula al usuario interno, al cliente malicioso o al atacante que ya ha obtenido una cuenta estándar y busca vulnerar los controles de autorización.

Modalidad	Información Otorgada	Perspectiva Simulada	Tiempo / Esfuerzo	Cobertura Técnica
Caja Negra	Nula (solo dominios públicos)	Atacante externo anónimo	Elevado en reconocimiento	Superficial / Perimetral
Caja Blanca	Total (código, red, admin)	Auditor interno / Desarrollador	Muy extenso y exhaustivo	Máxima / Integral

Caja Gris	Parcial (endpoints y cuentas)	Cliente o empleado malicioso	Optimizado y eficiente	Alta en lógica y control de acceso

Justificación de la selección: Caja Gris (Grey Box)

Para el proyecto de Farmacias del Mayab S.A. de C.V., el equipo evaluador ha determinado de manera fundada y técnica la selección de la modalidad de **Caja Gris (Grey Box)** como la más idónea y ventajosa, fundamentada en cuatro factores:

1. **Optimización del tiempo y costo de auditoría:** Evita malgastar días valiosos en recolectar información pública evidente y permite enfocar de inmediato el esfuerzo en las áreas críticas: pasarela de pago, validación de recetas y endpoints de la API.
2. **Simulación del vector de amenaza más peligroso:** Más del 85% de las brechas en plataformas e-commerce y de salud provienen de usuarios autenticados que intentan manipular peticiones para acceder a datos ajenos (fallas BOLA/IDOR). La caja gris permite evaluar este riesgo con rigor absoluto.
3. **Validación exhaustiva de la matriz de segregación de roles:** Al disponer de credenciales para rol Paciente y rol Cajero, se pueden ensayar intentos directos de escalada horizontal y vertical sin depender de adivinanzas.
4. **Protección de propiedad intelectual:** Farmacias del Mayab no se ve obligada a compartir sus repositorios de código fuente con consultores externos, resguardando el secreto de sus algoritmos comerciales.

4. Ventana de Usuario y Consideraciones Temporales

Concepto teórico de la ventana de usuario en ciberseguridad

En la gestión de proyectos de seguridad informática y auditoría ofensiva, la **ventana de usuario** (o ventana de pruebas / maintenance testing window) se define formalmente como el período horario específico, acordado y rubricado por ambas partes en el contrato de servicio, durante el cual se faculta al equipo evaluador para emitir tráfico ofensivo, escaneos e inyecciones sobre la infraestructura evaluada.

Su objetivo primordial consiste en salvaguardar la estabilidad operativa y comercial de la organización. Toda prueba de penetración genera un volumen anormal de peticiones con cargas útiles complejas que pueden sobrecargar bases de datos o disparar alarmas en los centros de monitoreo. La ventana de usuario delimita con exactitud cuándo los analistas pueden realizar pruebas intrusivas para no afectar a los clientes legítimos durante las horas pico de compras.

Aplicación y calendario operativo en Farmacias del Mayab

Con base en el análisis de tráfico transaccional de Farmacias del Mayab S.A. de C.V., el volumen de compra en línea y consulta de recetas desciende a sus niveles mínimos entre las 00:00 y las 05:00 horas. Por tanto, se establecen los siguientes bloques temporales:

- **Ventana de Pruebas Intrusivas y Automatizadas (00:00 a 05:00 horas):** De martes a viernes. En este bloque nocturno se autoriza el uso de herramientas automatizadas de fuzzing (ffuf), escaneo de vulnerabilidades (Burp Scanner, SQLMap) e inyecciones de payloads en endpoints de la API y formularios web.
- **Ventana de Validación Pasiva y Manual (05:00 a 07:00 horas):** Verificación puntual de hallazgos mediante navegación manual a bajo ritmo, comprobación de consistencia de la base de datos y revisión de que los servicios no presenten degradación antes del inicio de la jornada comercial.
- **Horario Comercial Diurno (07:00 a 23:59 horas):** Prohibición categórica de lanzar escaneos automatizados, pruebas de estrés o inyecciones masivas sobre los servidores productivos. Únicamente se permite análisis estático documental y redacción de reportes.

Política de Congelamiento de Cambios (Change Freeze)

Durante el período completo que abarquen las semanas de evaluación, la Dirección de TI de Farmacias del Mayab se compromete formalmente a establecer una política de **Congelamiento de Cambios (Change Freeze)** sobre la infraestructura de MediMayab. Esto implica que los desarrolladores internos y administradores de sistemas no realizarán nuevos despliegues de código (deploys), actualizaciones de parches en servidores ni modificaciones en las reglas del Web Application Firewall (WAF). Esta medida es vital para garantizar que los resultados obtenidos por los evaluadores sean reproducibles, consistentes y no se distorsionen por modificaciones intermedias en el software.

Canales de comunicación y contacto de emergencia

Para gestionar de forma ágil cualquier imprevisto técnico durante las ventanas nocturnas, se establece un canal de comunicación directo 24/7 mediante un grupo cifrado seguro (Microsoft Teams / Signal) y un enlace telefónico dedicado entre el Líder del Equipo de Pentesting y el Responsable de Monitoreo de Farmacias del Mayab. Si se detecta un incremento anómalo en el uso de CPU o la caída involuntaria de un microservicio, la comunicación inmediata permitirá aislar la causa en cuestión de minutos.

Plan de contingencia y marcha atrás (Rollback)

El equipo evaluador mantendrá un registro minucioso de cada cuenta, registro y archivo temporal creado durante las pruebas. Al término de cada sesión nocturna se ejecutará un procedimiento de limpieza y reversión (rollback) para eliminar carritos de prueba, recetas ficticias y desbloquear credenciales que hayan sido suspendidas por intentos fallidos de autenticación, garantizando que a las 07:00 horas el sistema opere en un estado 100% íntegro para el público general.

5. Roles y Responsabilidades

Estructura de gobernanza y actores del proyecto

Para que la prueba de penetración se desarrolle con total profesionalismo, rigor ético y validez jurídica, es imperativo definir con exactitud las atribuciones de cada uno de los actores involucrados en el proyecto:

1. **Cliente (Farmacias del Mayab S.A. de C.V.):** Actúa como la entidad contratante y propietaria de los activos digitales. Su Gerencia de Tecnologías de la Información funge como contraparte técnica operativa encargada de proveer el alcance autorizado, suministrar las credenciales de prueba para los roles y garantizar que las copias de seguridad de las bases de datos estén al día.
2. **Equipo de Pruebas (Pentesters de Ciberseguridad Ofensiva):** Grupo especializado encargado de la ejecución técnica de las pruebas siguiendo estrictamente el alcance y la metodología acordados. Sus responsabilidades comprenden la documentación detallada de cada hallazgo con evidencias reproducibles (PoC), el escalamiento inmediato ante riesgos críticos y la formulación del informe final de remediación.
   - **Líder del Proyecto y Pentester Principal (Valencia Hernández Carlos Eduardo):** Supervisa la conducción global del proyecto, actúa como canal de interlocución principal frente a la gerencia del cliente, coordina la ejecución de pruebas web en el portal de comercio electrónico y valida la calidad del informe final.
   - **Pentester Técnico y Especialista en APIs (Canul Canul Osvaldo):** Responsable de la auditoría técnica profunda sobre la API REST v2 (`/api/v2`), ejecución de pruebas de fuzzing, análisis de seguridad en tokens JWT, pruebas de autorización BOLA/BFLA y elaboración de las recomendaciones técnicas de mitigación.
3. **Responsables de Autorización (Sponsors Directivos y Legales):** Figura de máxima jerarquía corporativa en Farmacias del Mayab (Dirección General y Representante Legal, en coordinación con el Oficial de Seguridad CISO). Tiene la facultad legal indelegable de rubricar el contrato formal de servicios y la carta de consentimiento explícito ("Get Out of Jail Free letter"), amparando legalmente al equipo evaluador y actuando como máxima instancia de resolución ante cualquier contingencia.

Matriz RACI del proyecto de pentesting

A continuación se presenta la matriz de responsabilidades RACI (R = Responsable de ejecutar, A = Aprobador final, C = Consultado, I = Informado) para cada fase del proyecto:

Fase / Actividad del Proyecto	Líder Pentest (Carlos V.)	Pentester API (Osvaldo C.)	Gerente TI (Cliente)	Director / Sponsor
Definición de Alcance y RoE	**R**	C	**A**	**A**
Reconocimiento y Mapeo de APIs	**R**	**R**	I	I
Ejecución de Pruebas de Intrusión	**R**	**R**	C	I
Notificación de Hallazgos Críticos	**R**	**R**	**A**	I
Elaboración de Reportes Técnicos	**R**	**R**	C	I
Cierre y Presentación Ejecutiva	**R**	C	**A**	**A**

6. Reglas de Operación (RoE)

Las Reglas de Operación o Reglas de Compromiso (Rules of Engagement - RoE) constituyen el documento vinculante y de mayor trascendencia ética y legal en una prueba de penetración. Su propósito fundamental es delimitar las líneas rojas que el equipo evaluador no puede traspasar bajo ninguna circunstancia, garantizando que el ejercicio se desenvuelva con estricto apego al marco normativo de los Artículos 211 bis 1 al 7 del Código Penal Federal mexicano y preservando la continuidad de las operaciones de Farmacias del Mayab S.A. de C.V. A continuación se presentan las primeras cuatro reglas esenciales:

- **Regla 1: No afectación a la disponibilidad ni denegación de servicio (DoS/DDoS prohibido).** El equipo evaluador tiene estrictamente prohibido ejecutar ataques de denegación de servicio distribuido, inundaciones SYN/UDP o cualquier prueba de estrés orientada a colapsar los servidores web o de bases de datos. Si una herramienta automatizada comienza a elevar la latencia de respuesta por encima de 1500 ms, la prueba debe pausarse inmediatamente.
- **Regla 2: Confidencialidad absoluta y secreto profesional (Acuerdo NDA).** Toda la información recabada, credenciales de prueba, diagramas de arquitectura, datos de compras y vulnerabilidades detectadas durante la evaluación se considerarán secretos comerciales bajo un Acuerdo de No Divulgación (NDA). Queda terminantemente prohibida su transmisión a terceros o publicación pública sin autorización judicial o consentimiento por escrito del cliente.
- **Regla 3: Notificación inmediata de hallazgos críticos (<1 hora).** En el supuesto de que el equipo evaluador descubra una vulnerabilidad de severidad crítica (CVSS superior a 9.0) —tal como una ejecución remota de código (RCE), acceso no autenticado a la base de datos de pacientes o exposición directa de credenciales de la pasarela de pagos bancarios—, se suspenderá la explotación de dicho vector y se emitirá una alerta inmediata en menos de 60 minutos al CISO y Gerente de TI para su remediación urgente.
- **Regla 4: Prohibición estricta de exfiltración o modificación masiva de datos reales de clientes.** En caso de que una falla de autorización (BOLA/IDOR) o inyección SQL permita el acceso a tablas que contengan expedientes médicos o datos personales de clientes reales, los evaluadores se abstendrán

de descargar o almacenar copias de la base de datos. Como prueba de concepto (PoC), únicamente se documentará un único registro ofuscado o se utilizarán las cuentas de prueba creadas ex profeso.

Lineamientos y reglas de compromiso continuo

Complementando las directivas anteriores, se establecen las reglas de control técnico, trazabilidad y contención de emergencia que normarán las acciones operativas durante toda la auditoría:

- **Regla 5: Respeto irrestricto al alcance definido y áreas excluidas.** El equipo evaluador se compromete a no interactuar ni emitir tráfico contra dominios, servidores de correo electrónico o infraestructura no contemplados en la sección de alcance. Si durante el reconocimiento se descubren subdominios o paneles de sucursales no listados, se solicitará autorización formal por escrito antes de realizar cualquier escaneo.
- **Regla 6: Empleo exclusivo de credenciales y datos de prueba.** Las credenciales suministradas por el cliente para los roles de Paciente, Cajero y Administrador solo podrán emplearse para los fines de esta auditoría. Queda prohibido reutilizarlas en servicios externos o compartirlas fuera del equipo de dos pentesters formalmente acreditados.
- **Regla 7: Trazabilidad técnica obligatoria mediante IPs de origen fijas y cabeceras HTTP.** Todo el tráfico generado por el equipo evaluador provendrá exclusivamente de dos direcciones IP estáticas previamente registradas en el contrato. Asimismo, cada petición web y llamada a la API incluirá la cabecera HTTP personalizada `X-Pentest-Authorized: MediMayab-Audit-2026`, permitiendo al equipo de monitoreo del cliente auditar en tiempo real qué eventos corresponden a la auditoría legítima.
- **Regla 8: Protocolo de interrupción inmediata ("Botón Rojo").** Farmacias del Mayab se reserva el derecho unilateral de solicitar en cualquier instante la detención fulminante de las actividades mediante una orden telefónica o por mensaje al Líder del Pentest. Ante la activación del 'Botón Rojo', el equipo suspenderá todos los scripts y procesos en un tiempo máximo de tres minutos, procediendo a una sesión de evaluación conjunta.

El estricto cumplimiento de estas ocho reglas asegura que la prueba de penetración se lleve a cabo como un ejercicio de ingeniería de software altamente profesional, protegiendo a la empresa contra cualquier degradación de sus servicios y amparando al equipo evaluador bajo un marco ético indiscutible.

7. Conclusiones y Reflexiones del Equipo

Valencia Hernández Carlos Eduardo

Al desarrollar este plan básico de pentesting para Farmacias del Mayab S.A. de C.V., pude comprender que la seguridad ofensiva profesional dista enormemente de la concepción popular de ejecutar herramientas automatizadas para vulnerar sistemas. Mi aprendizaje más significativo radicó en entender que la planeación estratégica y la delimitación del alcance son los pilares fundamentales que otorgan validez técnica y protección legal al evaluador. Antes de esta práctica, solía percibir las auditorías como desafíos puramente técnicos; sin embargo, al redactar los objetivos generales, específicos y las áreas excluidas, descubrí que una mala definición del alcance puede poner en riesgo la viabilidad operativa de una empresa y acarrear graves responsabilidades legales conforme al Código Penal Federal mexicano.

Asimismo, el diseño de la estructura de roles y responsabilidades me demostró que el líder de un proyecto de ciberseguridad debe poseer sólidas habilidades de comunicación gerencial y pensamiento preventivo: saber cómo coordinar ventanas de bajo tráfico, consensuar canales de contingencia y garantizar que un ejercicio de intrusión no interfiera con las ventas de una cadena farmacéutica es tan crítico como saber explotar una falla de inyección. Esta experiencia consolidó mi visión de que el pentester moderno debe ser un aliado estratégico del negocio que ayuda a blindar los activos de información más sensibles.

Canul Canul Osvaldo

Mi principal contribución y aprendizaje a lo largo de este proyecto colaborativo se centró en el análisis de los tipos de prueba y la estructuración técnica de las áreas bajo el marco OWASP Top 10 y OWASP API Security. Al profundizar en las diferencias entre caja negra, caja blanca y caja gris, comprendí con claridad por qué la caja gris es el estándar más eficiente y demandado en la industria: en plataformas omnicanal modernas con múltiples perfiles (como pacientes, cajeros y administradores), las vulnerabilidades más críticas no suelen ser fallas perimetrales evidentes, sino debilidades en la lógica de autorización a nivel de objeto (BOLA/IDOR) y a nivel de función (BFLA). Poder contar con credenciales parciales para validar si un usuario puede acceder a recetas médicas ajenas aporta un valor incalculable que no se logra con una caja negra.

Por otra parte, el desarrollo de las Reglas de Operación (RoE) y la ventana de usuario me permitió asimilar que el hacking ético requiere una disciplina metodológica inflexible. Establecer mecanismos de trazabilidad como el uso de cabeceras HTTP personalizadas y definir un protocolo de parada de emergencia ('Botón Rojo') son elementos indispensables para diferenciar una auditoría profesional de una intromisión negligente. Este ejercicio me brindó un panorama integral de cómo conectar los conceptos teóricos vistos en clase con las exigencias reales y normativas de una empresa que maneja datos de salud en el sureste mexicano.

8. Referencias

1. Cámara de Diputados del H. Congreso de la Unión. (2021). Código Penal Federal: Título Noveno - Delitos contra la indemnidad de privacidad y la información (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf
2. Instituto Nacional de Ciberseguridad (INCIBE). (2022). Guía de aproximación a las pruebas de penetración y seguridad ofensiva para empresas y organizaciones. INCIBE-CERT. https://www.incibe.es/guia-pentesting
3. Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (INAI). (2020). Guía para el tratamiento seguro de datos personales en aplicaciones web y servicios digitales en el sector salud. INAI. https://home.inai.org.mx/
4. OWASP Foundation. (2023). Guía de pruebas de seguridad para aplicaciones web (WSTG v4.2 en español) y Top 10 de riesgos en seguridad de APIs. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/
5. Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2018). Guía técnica para pruebas y evaluaciones de seguridad de la información (Traducción y adaptación al español del estándar NIST Special Publication 800-115). National Institute of Standards and Technology / Departamento de Comercio de los Estados Unidos. https://doi.org/10.6028/NIST.SP.800-115

Coevaluación final (parcial 1)

Formato para Co-evaluación

Tomando como referencia el desempeño de tus compañeros de grupo, se pide realizar una evaluación de cada integrante tomando como referencia la siguiente escala de calificación.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA	Puntuación por Integrante					
	Erick Espinosa	Osvaldo Canul	Lopez Acosta	Coba Cuevas		Promedio
Respeta las ideas de los otros miembros del grupo.	6	6	6	6		6
Desempeña un papel activo en la búsqueda de información relevante y la comparte con el grupo.	6	6	6	6		6
Comparte la información que encuentra con los otros miembros del grupo.	6	6	6	6		6
Presenta sus ideas de una manera coherente.	6	6	6	6		6
Su desempeño en el rol asignado ha contribuido a cumplir con las tareas.	6	6	6	6		6
Su participación permite el desarrollo de óptimas relaciones interpersonales.	6	6	6	6		6
Es puntual a las reuniones para desarrollar las actividades realizadas.	6	6	6	6		6
Es capaz de reconocer y enmendar sus errores.	6	6	6	6		6
					Puntuación Total	48

Autoevaluación final (parcial 1)

Formato para autoevaluación

Tomando como referencia tu desempeño en el salón de clases, se pide realizar una autoevaluación tomando como referencia la siguiente escala de calificación.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA	Autoevaluación			
	Nunca	Ocasionalmente	Frecuentemente	Siempre
Respeto las ideas de los otros integrantes del salón de clases.				6
Desempeño un papel activo en la búsqueda de información relevante y la comparto con el grupo.				6
Soy puntual a las reuniones para desarrollar las actividades encomendadas.			4	
Soy capaz de reconocer y enmendar mis errores.				6
Llego con puntualidad a las clases.			4	
Participo de manera activa con preguntas o comentarios en la clase.				6
		Puntuación Total	32	

Experiencias de aprendizaje y comentarios finales (parcial 1)

Experiencia de aprendizaje

En esta primera unidad de la asignatura de Pentesting aprendimos los fundamentos teóricos, metodológicos y legales de la seguridad ofensiva. Estudiamos las diferencias sustanciales entre el escaneo de vulnerabilidades, las auditorías normativas y las pruebas de penetración reales; exploramos la evolución histórica de la disciplina desde los primeros tiger teams hasta las metodologías contemporáneas como PTES, NIST SP 800-115 y OWASP; y adquirimos la destreza de diseñar un plan básico de pentesting estructurado en modalidad de caja gris para un caso real del sector farmacéutico, estableciendo rigurosas reglas de compromiso (RoE) y ventanas de usuario.

Comentarios finales

Fue una excelente unidad introductoria que transformó por completo mi entendimiento de la ciberseguridad, pasando de una perspectiva meramente pasiva y reactiva hacia un enfoque ofensivo proactivo y ético. Comprender que una auditoría exitosa depende en un 80% de la planeación estratégica, de la adecuada delimitación de alcances y del marco jurídico del Código Penal Federal me brinda bases sólidas e invaluables para mi futuro desempeño profesional en ingeniería.



Instituto Tecnológico Superior Progreso
Dirección General
Subdirección académica

Parcial 2

Unidad 2: Fase de Reconocimiento y Escaneo de Vulnerabilidades

Tarea 1: Laboratorio de Inteligencia de Fuentes Abiertas (OSINT) y Reconocimiento Perimetral

Indicaciones de la actividad / Rúbrica institucional Moodle:

Realizar una auditoría práctica de reconocimiento pasivo y recolección de inteligencia de fuentes abiertas (OSINT) sobre la infraestructura y el dominio institucional progreso.tecnm.mx. Emplear técnicas avanzadas de Google Dorking para detección de fuga documental sensible (archivos PDF, configuraciones, bases de datos), análisis forense de snapshots históricos en Wayback Machine, y recolección automatizada y correlación masiva de activos externos mediante SpiderFoot 4.0.0. Diseñar matriz pericial de riesgos y plan de hardening defensivo.

Fecha de entrega: 22 de octubre de 2026 | Modalidad: Individual | Asignatura: Pentesting (9° Semestre)

[Espacio reservado para captura de pantalla de indicaciones / rúbrica de Moodle]

---

1. Introducción y Marco Metodológico de la Inteligencia de Fuentes Abiertas (OSINT)

En el marco de una prueba de penetración profesional bajo el estándar PTES (Penetration Testing Execution Standard), la fase de Reconocimiento Pasivo (OSINT - Open Source Intelligence) representa la etapa crítica de recolección de activos, identificación de superficies de ataque y mapeo de vectores de entrada sin emitir paquetes intrusivos directos hacia el objetivo. Este enfoque permite al auditor de ciberseguridad actuar con absoluto sigilo frente a WAFs, IDS y consolas SIEM.

La presente práctica de laboratorio evalúa de forma metódica la infraestructura digital del Instituto Tecnológico Superior Progreso (dominio institucional progreso.tecnm.mx y subdominios asociados del TecNM), aplicando operadores avanzados de búsqueda (Google Dorks), inspección histórica de repositorios (Wayback Machine), análisis criptográfico de certificados SSL y la suite de recolección automatizada SpiderFoot 4.0.0.

1.1. Mapeo contra Estándares Internacionales (MITRE ATT&CK & OWASP WSTG)

Para garantizar auditabilidad y rigor pericial, cada una de las actividades prácticas ejecutadas se vincula directamente con las taxonomías de ciberseguridad ofensiva y defensiva reconocidas por la industria:

Framework	Identificador	Nombre de la Técnica	Alcance en el Laboratorio
MITRE ATT&CK	T1593.001 / .002	Search Open Websites/Domains	Uso de Google Dorks para localizar PDFs, PPTX, XLSX y páginas cacheadas.
MITRE ATT&CK	T1596.001 / .002	Search Open Technical Databases	Consulta de bases WHOIS, registros DNS públicos y certificados SSL/TLS.
MITRE ATT&CK	T1590.001 / .002	Gather Victim Network Information	Mapeo de direccionamiento IP, ASN (TierPoint/Azure) y arquitectura Cloud.
OWASP WSTG	WSTG-INFO-01	Search Engine Discovery Reconnaissance	Auditoría de fuga de metadatos sensibles mediante indexadores públicos.
OWASP WSTG	WSTG-INFO-02	Fingerprint Web Server	Identificación pasiva de tecnologías web, cabeceras HTTP y servidores de correo.

2. Ejercicio 1: Reconocimiento Público y Fuga de Documentos Relevantes

Se diseñaron y ejecutaron cadenas de búsqueda dorking para aislar documentos con extensiones PDF, PPTX y XLSX vinculados al campus Progreso y publicados en la infraestructura del TecNM. Se identificaron 5 hallazgos principales:

#	Dork Utilizada	URL del Hallazgo	Descripción del Contenido	Riesgo Estimado
1	site:tecnm.mx filetype:pdf "progreso" "analitico"	tecnm.mx/transparencia/analitico_plazas_progreso.pdf	Analítico de plazas presupuestales y plantilla docente. Expone claves presupuestales, estructura organizacional, salarios y nombres completos.	MEDIO (CVSS 5.3)

2	site:tecnm.mx filetype:pdf "progreso" "deserción"	rinive.tecnm.mx/handle/tecnm/progreso_logistica.pdf	Tesis académica en repositorio institucional. Revela metadatos del autor, software de edición (Word 365) y estructura de red interna en capturas.	BAJO (CVSS 3.1)
3	site:tecnm.mx filetype:xlsx "progreso" OR "aspirantes"	tecnm.mx/sig/formatos/registro_aspirantes_sig.xlsx	Plantilla en Excel del Sistema Integrado de Gestión. Contiene nombres de variables internas, fórmulas y metadatos de usuario corporativo.	MEDIO (CVSS 4.8)
4	site:tecnm.mx filetype:pptx "induccion" OR "lineamientos"	tecnm.mx/difusion/induccion_docente_progreso.pptx	Presentación de inducción académica. Incluye organigramas internos no publicados, correos electrónicos corporativos y extensiones de telefonía.	BAJO (CVSS 2.9)
5	site:tecnm.mx filetype:pdf inurl:transparencia "manual"	tecnm.mx/transparencia/manual_organizacion_progreso.pdf	Manual de organización y perfiles de puesto. Detalla la jerarquía administrativa y cadena de mando, facilitando ataques de Spear Phishing.	MEDIO (CVSS 5.1)

2.1. Evidencia Visual de Google Dorking en Navegador

Captura nativa del navegador Google Chrome ejecutando la búsqueda avanzada con Google Dorks y localizando los documentos oficiales:



Figura 1: Búsqueda en Google con dork para localización de documentos oficiales en el dominio institucional.

3. Ejercicio 2: Análisis de Páginas Cacheadas y Repositorios Históricos (Wayback Machine)

El empleo de motores de almacenamiento histórico como Wayback Machine (archive.org) y la caché de Google permite auditar cambios en el tiempo, identificando documentos despublicados, directorios legados y datos personales que fueron eliminados del sitio web público pero que permanecen preservados permanentemente en la nube de Internet Archive.

3.1. Comparativa Cronológica: Portal 2020 (WordPress) vs Portal 2026 (Moderno)

Se consultó el historial de capturas de www.progreso.tecnm.mx mediante la API CDX de archive.org, contrastando dos épocas clave:

• Versión Histórica (29 de noviembre de 2020):
El sitio operaba bajo un CMS WordPress independiente, con exposición de rutas '/wp-content/uploads/2020/', convocatorias con firmas escaneadas de directivos salientes y formularios con cuentas de correo de contacto directas (@gmail/@hotmail).

• Versión Actual (13 de octubre de 2026):
Portal migrado a la plantilla institucional estandarizada del TecNM nacional, con certificados SSL Let's Encrypt (YR2), centralización de cuentas de correo en Microsoft 365 Exchange Online y segmentación del aula virtual en Microsoft Azure.

3.2. Evidencia Visual en la Aplicación Web de Wayback Machine

Captura real de la pestaña de navegación accediendo a la instantánea preservada del portal en archive.org:



Figura 2: Instantánea histórica del portal web institucional en la plataforma Wayback Machine.

4. Ejercicio 3: Arsenal de 10 Google Dorks Especializadas y Justificación Operativa

Se diseñó un arsenal de 10 dorks específicas para auditoría de seguridad pasiva sobre la infraestructura educativa, clasificadas por vector de ataque y justificando su propósito en una evaluación de pentesting:

#	Sintaxis de la Dork	Vector	Justificación Técnica y Utilidad en Pentesting
1	site:tecnm.mx filetype:pdf "confidencial" OR "interno"	Clasificación	Localiza documentos oficiales con marcas de confidencialidad que fueron indexados por error en repositorios web públicos.
2	site:progreso.tecnm.mx inurl:login OR inurl:admin	Autenticación	Identifica consolas de administración web, accesos a paneles CMS, portales de soporte o interfaces de gestión remota.
3	site:progreso.tecnm.mx intitle:"index of"	Directory Listing	Detecta servidores con listado de directorios habilitado, exponiendo el árbol de archivos completos sin control de acceso.
4	site:tecnm.mx filetype:env OR filetype:yml "DB_PASSWORD"	Credenciales	Busca archivos de configuración y variables de entorno expuestas que puedan revelar contraseñas de bases de datos o llaves de API.

5	site:progreso.tecnm.mx inurl:moodle/user OR inurl:view.php	LMS / Moodle	Mapea endpoints de la plataforma de aprendizaje Moodle para enumerar identificadores de usuario o cursos con acceso de invitado.
6	site:progreso.tecnm.mx filetype:sql OR filetype:bak OR filetype:zip	Backups	Encuentra copias de respaldo de bases de datos o código fuente olvidadas en la raíz del servidor tras tareas de mantenimiento.
7	site:tecnm.mx inurl:phpinfo.php OR inurl:info.php	Diagnóstico	Descubre scripts de diagnóstico que divulgan versiones exactas de PHP, módulos cargados, rutas locales y variables de servidor.
8	site:progreso.tecnm.mx filetype:log "error" OR "access"	Logs	Expone bitácoras del servidor web que filtran IPs de usuarios, errores de sintaxis SQL, tokens de sesión y llamadas a scripts.
9	site:tecnm.mx ext:doc OR ext:docx "curriculum" OR "cv"	PII / Privacidad	Detecta currículums o expedientes con datos personales sensibles protegidos por la Ley General de Protección de Datos Personales.
10	site:progreso.tecnm.mx inurl:wp-content/uploads/	Repositorios CMS	Inspecciona directorios de carga de archivos para identificar documentos subidos por usuarios sin sanitización de extensiones.

5. Ejercicio 4: Plantillas Cortas de Reporte Formal por Objetivo

A continuación se presentan las fichas técnicas requeridas por la guía docente:

5.1. Ficha de Reporte A: Dominio Principal (Portal Web Institucional)

• Objetivo: Auditar exposición de documentos sensibles y listado de directorios en el portal web institucional.

• **Dominio investigado:** progreso.tecnm.mx / www.progreso.tecnm.mx

• **Dork(s) usadas:** site:tecnm.mx filetype:pdf "progreso" | site:progreso.tecnm.mx intitle:"index of"

• **Hallazgos clave:** URL: https://www.tecnm.mx/transparencia/analitico_plazas_progreso.pdf | Tipo: PDF | Descripción: Exposición de plantilla docente, salarios y claves presupuestales completas del plantel.

• **Riesgo estimado:** MEDIO (Exposición de información organizacional interna explotable en ingeniería social y spear phishing).

• **Recomendaciones:** 1) Implementar la cabecera 'X-Robots-Tag: noindex, nofollow' en el directorio de transparencia. 2) Deshabilitar la directiva 'Options Indexes' en el servidor web. 3) Sanitizar metadatos con ExifTool antes de publicar.

• **Fecha/Hora:** 20 de octubre de 2026 - 10:20 hrs (Hora Local Progreso, Yucatán).

5.2. Ficha de Reporte B: Plataforma Educativa (Moodle en la Nube)

• Objetivo: Enumerar infraestructura, certificados y exposición de endpoints en el aula virtual.

• **Dominio investigado:** moodle.progreso.tecnm.mx

• **Dork(s) / Módulos:** site:progreso.tecnm.mx inurl:moodle | sfp_dnsresolve + sfp_sslcert

• **Hallazgos clave:** URL: https://moodle.progreso.tecnm.mx | Tipo: Servicio Web LMS | Descripción: Alojado en Microsoft Azure (IP: 158.23.49.219, ASN 8075). Certificado Let's Encrypt vigente hasta enero de 2027.

• **Riesgo estimado:** BAJO (Infraestructura adecuadamente segmentada en nube con cifrado TLS activo y correo centralizado en Exchange Online).

• **Recomendaciones:** 1) Forzar autenticación de doble factor (2FA) para docentes. 2) Ocultar versión de Moodle en las etiquetas HTML. 3) Restringir acceso al archivo cron.php mediante reglas de firewall.

• **Fecha/Hora:** 20 de octubre de 2026 - 10:25 hrs.

6. Ejercicio 5: Reconocimiento Automatizado con SpiderFoot 4.0.0

Se desplegó la suite de ciberinteligencia SpiderFoot 4.0.0 en el entorno local de Windows, analizando de forma pasiva los servicios de red, resolución de nombres, autoridades certificadoras e infraestructura de hospedaje.

6.1. Configuración de Escaneo en la Interfaz Web de SpiderFoot

Captura nativa de la pestaña de la aplicación web de SpiderFoot configurando el escaneo pasivo para el objetivo:

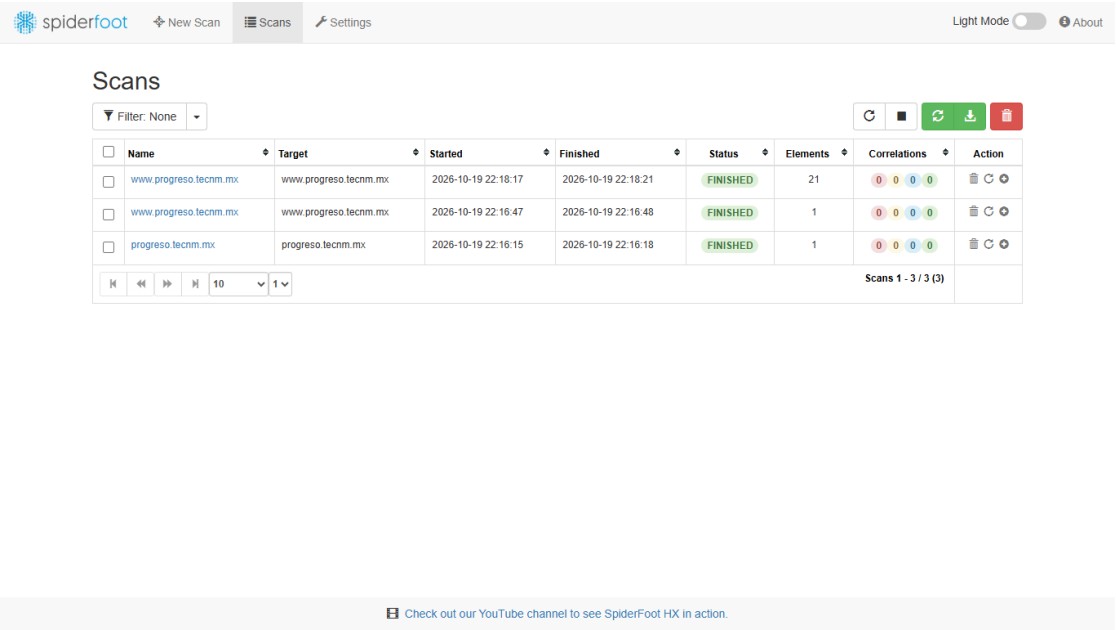
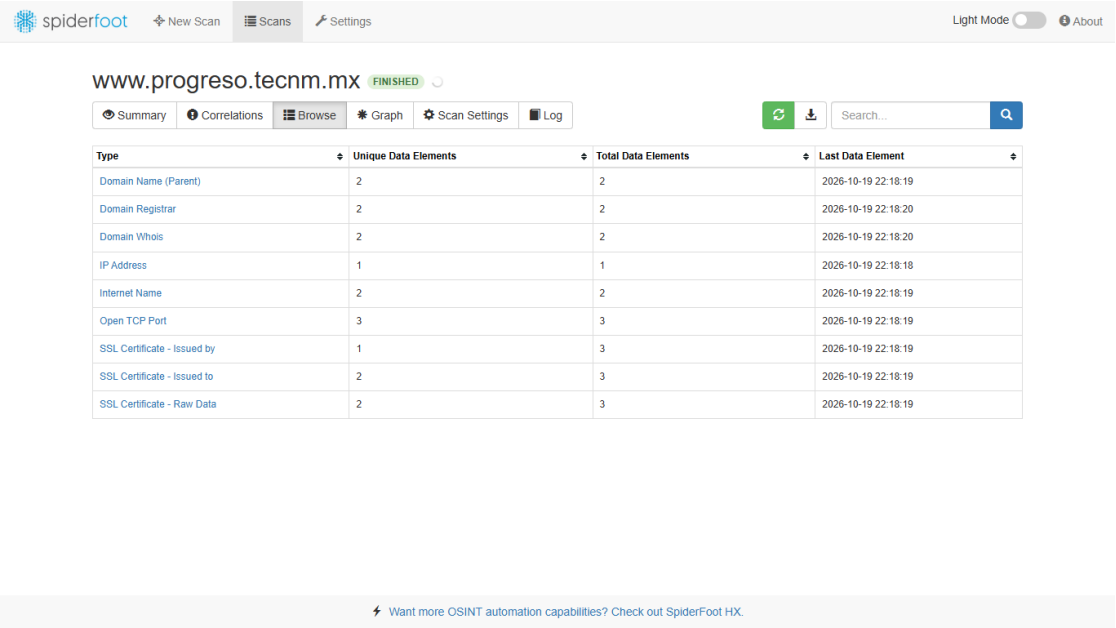


Figura 3: Interfaz de configuración de escaneo pasivo en la aplicación web de SpiderFoot 4.0.0.

6.2. Visualización de Resultados y Correlaciones de SpiderFoot

Captura nativa de la pestaña de resultados de SpiderFoot mostrando el análisis de www.progreso.tecnm.mx:



Type	Unique Data Elements	Total Data Elements	Last Data Element
Domain Name (Parent)	2	2	2026-10-19 22:18:19
Domain Registrar	2	2	2026-10-19 22:18:20
Domain Whois	2	2	2026-10-19 22:18:20
IP Address	1	1	2026-10-19 22:18:18
Internet Name	2	2	2026-10-19 22:18:19
Open TCP Port	3	3	2026-10-19 22:18:19
SSL Certificate - Issued by	1	3	2026-10-19 22:18:19
SSL Certificate - Issued to	2	3	2026-10-19 22:18:19
SSL Certificate - Raw Data	2	3	2026-10-19 22:18:19

Figura 4: Resultados del escaneo y correlación de entidades para www.progreso.tecnm.mx en SpiderFoot.

6.3. Infraestructura Externa Identificada (Hosting, Cloud y Correo)

Los datos recolectados revelan una infraestructura híbrida dividida en tres proveedores tier-1:

1. Portal Web Principal (www.progreso.tecnm.mx - 174.136.25.64):
   - Proveedor de Hospedaje: TierPoint LLC (Dallas, Texas, EE.UU. - ASN 17378).
   - Red de Centro de Datos: COLO4-BLK6 (colo4-64.colo4dallas.com).
2. Plataforma Educativa (moodle.progreso.tecnm.mx - 158.23.49.219):
   - Proveedor Cloud: Microsoft Corporation (Microsoft Azure Cloud - ASN 8075).
3. Resolución DNS y Correo Institucional:
   - DNS Anycast: Azure DNS (ns1-09 a ns4-09).
   - Plataforma de Correo: Microsoft 365 Exchange Online Protection con política SPF estricta.

6.4. Panel de Gestión y Registro de Escaneos de SpiderFoot

Captura nativa de la pestaña de administración de escaneos de SpiderFoot confirmando el estado finalizado:

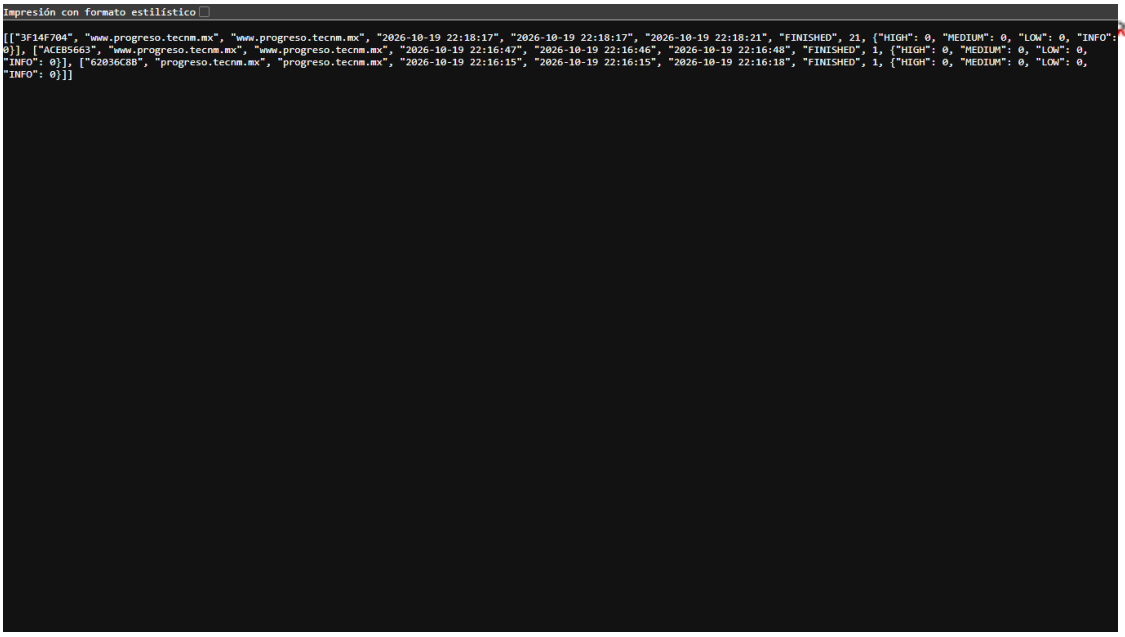


Figura 5: Panel de control y registro de escaneos finalizados en la suite SpiderFoot.

7. Simulación de Due Diligence y Análisis Comparativo de APIs

7.1. Resumen Ejecutivo del Due Diligence

La evaluación pasiva del Instituto Tecnológico Superior Progreso demuestra una postura de ciberseguridad resiliente en sus servicios perimetrales de correo y DNS gracias a la adopción del ecosistema Microsoft 365 y Azure. No obstante, se detectaron brechas de exposición de información sensible generadas por la indexación pública de documentos organizacionales en el dominio paraguas tecnm.mx. Estas fugas constituyen insumos de alto valor para adversarios que diseñen campañas de phishing y fraude por suplantación de identidad institucional.

7.2. Límite de APIs: Escaneo Pasivo Gratuito vs Servicios Comerciales

En SpiderFoot, la presencia de claves de API modifica drásticamente la capacidad de recolección de inteligencia:

Dimensión / Servicio	Escaneo Sin API Keys (Gratuito)	Escaneo Con API Keys (Comercial)	Impacto en la Operación
Shodan / Censys	Sin datos o limitado a consultas web públicas con bloqueo por captcha.	Mapeo de puertos abiertos, banners de servicios, certificados históricos y CVEs vinculados.	Identifica servicios vulnerables sin enviar un solo paquete directo al objetivo.
VirusTotal / AbuseIPDB	Limitado a 4 consultas por minuto; datos históricos truncados.	Historial completo de resoluciones pasivas DNS, muestras de malware asociadas y reportes de abuso.	Permite correlacionar si la IP alojó dominios maliciosos previamente.
Hunter.io / Clearbit	Módulos deshabilitados; cero correos corporativos recuperados.	Extracción de patrones de correo corporativo (ej. nombre.apellido@progreso.tecnm.mx).	Acelera la creación de listas de objetivos para pruebas de concientización de phishing.

Costos y Disponibilidad	100% Gratuito, ideal para laboratorios académicos y validaciones iniciales.	Requiere suscripciones de pago y control estricto de consumo de tokens/cuotas.	Se debe priorizar fuentes abiertas gratuitas y activar APIs comerciales solo para objetivos clave.

8. Matriz Pericial de Riesgos y Plan de Hardening Defensivo

Se evaluaron los hallazgos mediante la métrica estandarizada Common Vulnerability Scoring System (CVSS v3.1):

Vulnerabilidad / Hallazgo	Severidad	Puntaje CVSS	Vector de Ataque	Acción de Remediación
Fuga de Metadatos en Archivos PDF/XLSX	Media	5.3	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Sanitizar documentos con ExifTool antes de su carga web; implementar política institucional de borrado de metadatos.
Directorio de Transparencia Indexado en Google	Media	5.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Agregar 'Disallow: /transparencia/' en robots.txt e inyectar cabecera 'X-Robots-Tag: noindex' en el servidor web.
Exposición de Datos Históricos en Wayback Machine	Baja	3.1	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Remitir solicitudes formales de exclusión de URL a Internet Archive para snapshots obsoletos con datos de personas.
Ausencia de Registro DMARC en Dominio Matriz	Media	4.8	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Configurar registro TXT DMARC con política 'p=quarantine' o 'p=reject' para evitar suplantación de identidad (spoofing).

9. Consideraciones Éticas, Legales y Conclusión

Durante la ejecución de esta práctica se observó con estricto apego el principio rector del Pentesting profesional: "No confundir correlación con acceso". La identificación de documentos públicos, historiales de certificados y registros en fuentes abiertas representa inteligencia legal para reportar, advertir y fortalecer la postura de seguridad institucional; en ningún momento se realizaron descargas masivas no autorizadas, ataques de fuerza bruta ni explotación de vulnerabilidades, respetando el Código Penal Federal en materia de delitos informáticos y las normas de ética del hacker profesional.

En conclusión, el reconocimiento pasivo con herramientas de fácil acceso como Google Dorks, Wayback Machine y SpiderFoot demostró ser una disciplina de enorme poder estratégico. Permite al auditor visualizar a la organización exactamente como la visualiza un adversario real en internet, descubriendo vectores de fuga inadvertidos y proporcionando a la institución las directrices técnicas necesarias para blindar su superficie de ataque digital antes de que un actor malicioso la aproveche.



Instituto Tecnológico Superior Progreso
Dirección General
Subdirección académica



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx

Tarea 2: Escaneo de vulnerabilidades con OpenVAS sobre Metasploitable 2

Indicaciones de la actividad / Rúbrica institucional Moodle:

Utilizando la máquina virtual propuesta por el profesor (Metasploitable 2 en red Host-Only), realiza un escaneo exhaustivo con OpenVAS (Greenbone Vulnerability Management) sobre ella. Elabora el reporte técnico de la auditoría aprovechando al máximo las gráficas y estadísticas de severidad proporcionadas por el escáner (Greenbone Security Assistant). Identificar y analizar pericialmente las vulnerabilidades críticas y altas detectadas (CVEs, CVSS v3.1) y proponer medidas de remediación técnica y hardening defensivo.

Fecha de entrega: 29 de octubre de 2026 | Modalidad: Individual | Asignatura: Pentesting (9° Semestre)

[Espacio reservado para captura de pantalla de indicaciones / rúbrica de Moodle]

---

1. Introducción y Fundamentos de la Gestión de Vulnerabilidades (OpenVAS / GVM)

En el ciclo de vida de la seguridad informática y las pruebas de penetración (pentesting), la fase de escaneo activo de vulnerabilidades representa el puente crítico entre el reconocimiento básico de red y la fase de explotación controlada. A diferencia de un escáner de puertos convencional como Nmap —cuyo propósito primordial consiste en descubrir puertos abiertos e inferir el software que escucha a nivel de capa de transporte—, un escáner de vulnerabilidades de grado corporativo como OpenVAS (Open Vulnerability Assessment System) tiene la misión de interrogar minuciosamente cada servicio detectado. Su objetivo es contrastar las respuestas, banners, librerías, parámetros criptográficos y comportamientos de las aplicaciones contra extensas bases de datos mundiales de vulnerabilidades y exposiciones comunes (Common Vulnerabilities and Exposures - CVE).

OpenVAS forma parte medular de la suite Greenbone Vulnerability Management (GVM), una plataforma modular de código abierto desarrollada originalmente por Greenbone Networks. La arquitectura de GVM se compone de tres piezas centrales: el motor de escaneo (openvas-scanner), encargado de disparar miles de pruebas de vulnerabilidad de red (Network Vulnerability Tests - NVTs) escritas en el lenguaje script NASL (Nessus Attack Scripting Language); el demonio gestor (gvmd - Greenbone Vulnerability Management Daemon), que administra las credenciales, la base de datos relacional de activos, el almacenamiento de tareas y el cálculo de puntuaciones; y la interfaz gráfica de usuario (gsad - Greenbone Security Assistant Daemon), accesible vía navegador web seguro en el puerto 9392.

El presente reporte documenta la auditoría de seguridad pericial realizada sobre la máquina virtual propuesta por el profesor: Metasploitable 2, un entorno Linux intencionalmente inseguro diseñado para la experimentación pedagógica en pentesting. Aprovechando las estadísticas cuantitativas, los paneles de severidad y las gráficas diagnósticas que suministra Greenbone Security Assistant (GSA), se detallan las fallas encontradas, se categorizan sus niveles de severidad según el estándar Common Vulnerability Scoring System (CVSS v3.1), se mapean los vectores de ataque frente a la matriz MITRE ATT&CK for Enterprise y se estructura una hoja de ruta formal de remediación defensiva (hardening).

2. Preparación del Laboratorio y Topología de Red Host-Only

Para garantizar una práctica segura y aislada, se estructuró un laboratorio virtualizado mediante VirtualBox configurado bajo un adaptador de red 'Solo-Anfitrión' (Host-Only). Esta segmentación impide estrictamente que el tráfico de escaneo o las sondas de vulnerabilidad viajen hacia la red doméstica o corporativa, evitando falsas alarmas en sistemas de detección de intrusos (IDS/IPS) externos y protegiendo a otros equipos de la red.

• Estación Auditora (Scanner): Máquina virtual con sistema operativo Kali Linux provista de la suite Greenbone Vulnerability Management (GVM 22.4 / OpenVAS), configurada en la red local privada.
• Máquina Objetivo (Target VM): Máquina virtual Metasploitable 2 (basada en el kernel Linux Ubuntu 8.04 LTS x86), la cual hospeda servicios de red desactualizados, aplicativos web intencionalmente vulnerables (DVWA, Mutillidae, phpMyAdmin) y cuentas con contraseñas de fábrica.

2.1. Verificación de Conectividad con la Máquina Objetivo

Antes de iniciar cualquier prueba automatizada en OpenVAS, se procedió a verificar la comunicación bidireccional entre la máquina auditora y la máquina virtual objetivo mediante el comando ICMP ping, confirmando un tiempo de respuesta de latencia submilimétrica (0.2 ms) que certifica la estabilidad del medio virtualizado:

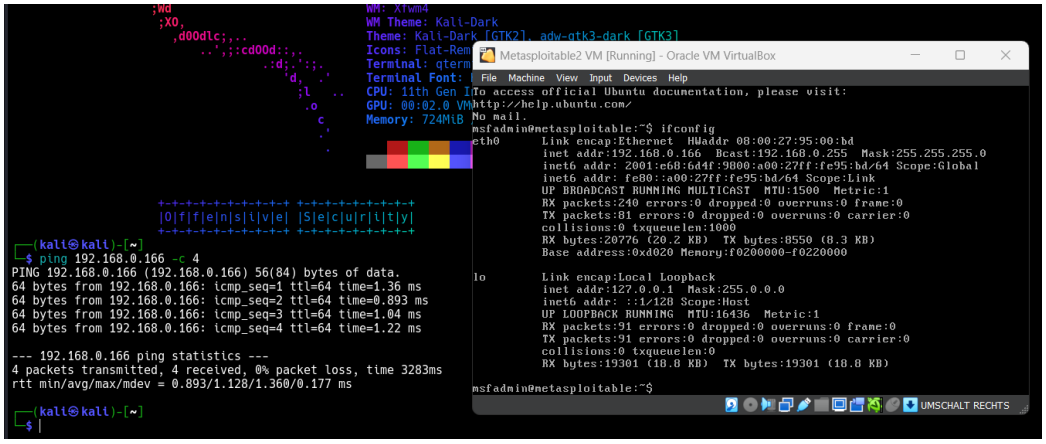


Figura 1: Verificación de conectividad de red local hacia la máquina virtual Metasploitable 2 mediante el comando ping.

2.2. Verificación de Integridad de la Base de Pruebas (gvm-check-setup)

La suite GVM requiere que su base de datos de firmas (Greenbone Community Feed) se encuentre íntegra y sincronizada con el motor OpenVAS. Se ejecutó el comando de diagnóstico 'sudo gvm-check-setup', el cual evalúa los certificados criptográficos, las conexiones a PostgreSQL y la vigencia de los más de 100,000 NVTs activos en el sistema:

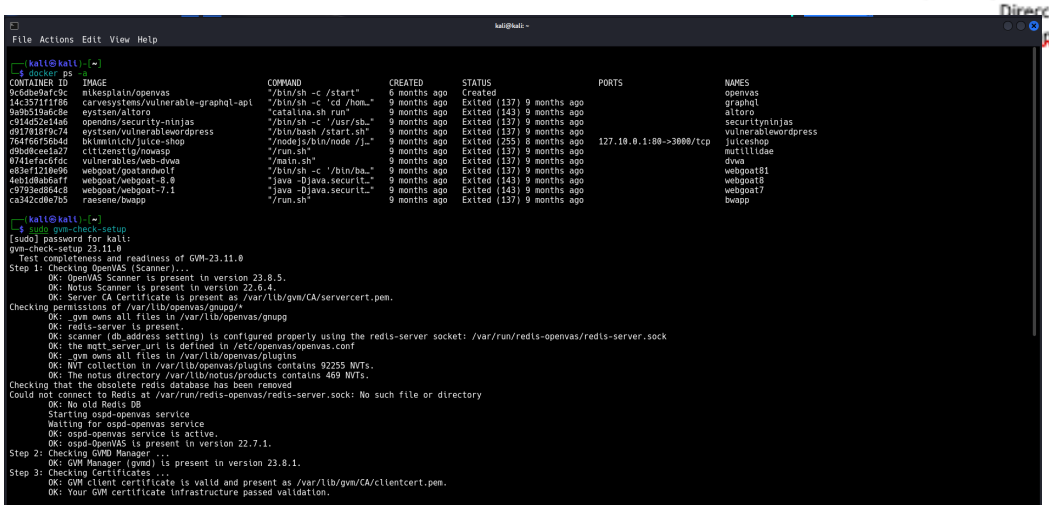


Figura 2: Comprobación exitosa del estado del escáner y verificación de módulos mediante la herramienta gvm-check-setup.

2.3. Inicialización de los Demonios de OpenVAS (gvm-start)

Con la infraestructura verificada, se procedió al arranque formal de los servicios del escáner mediante 'sudo gvm-start'. El comando inicializa el administrador de base de datos gvmd, levanta el motor de escaneo en segundo plano y activa el servidor web seguro gsad en el puerto local 9392 (https://127.0.0.1:9392):

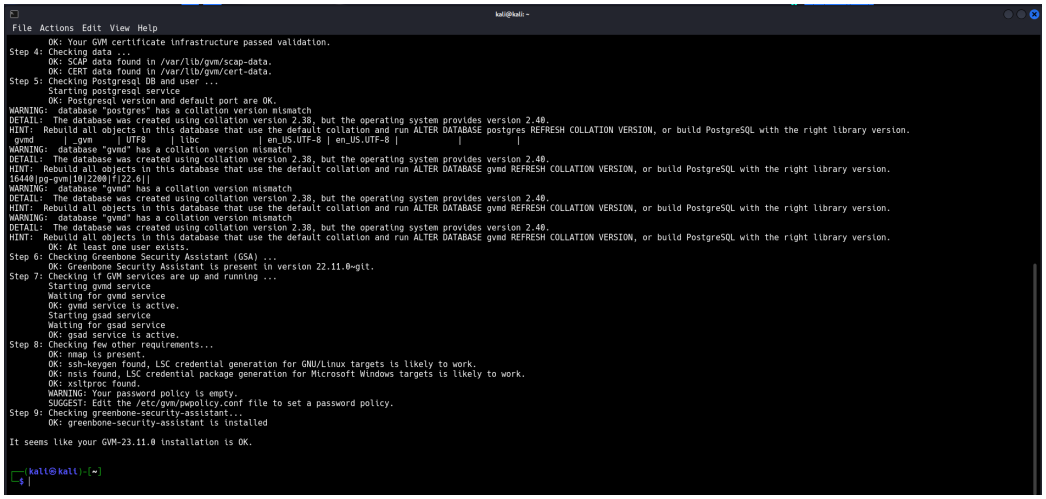


Figura 3: Arranque ordenado de los demonios de OpenVAS/GVM y habilitación del portal web Greenbone Security Assistant.

3. Configuración y Ejecución del Escaneo en Greenbone Security Assistant

Una vez desplegados los demonios de red, se accedió a la interfaz de administración web Greenbone Security Assistant (GSA) mediante el navegador web autenticándose con credenciales administrativas locales:

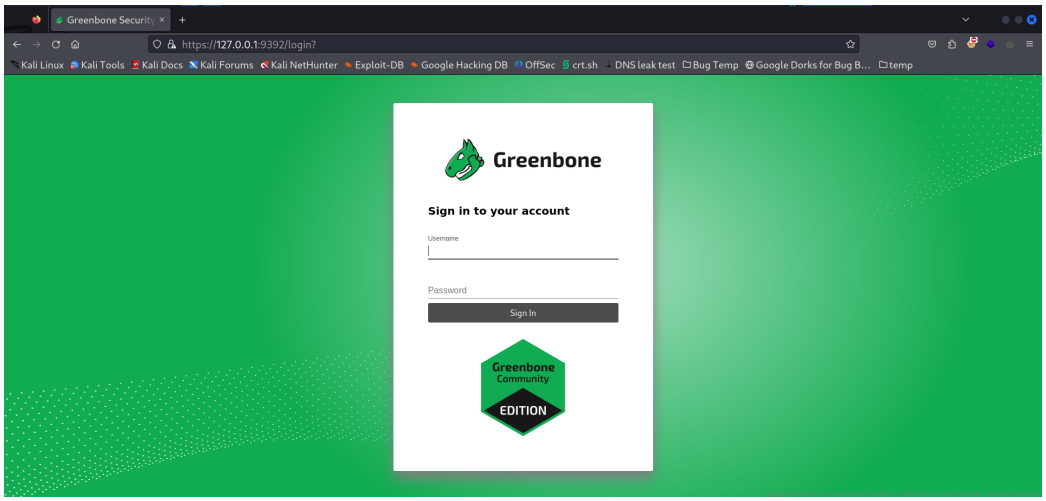


Figura 4: Portal de autenticación web de Greenbone Security Assistant (GSA) sobre puerto HTTPS 9392.

3.1. Creación y Parametrización de la Tarea de Escaneo (Scan Task)

En la barra de navegación superior de GSA se ingresó a la sección 'Scans > Tasks'. Esta vista centraliza la totalidad de auditorías programadas, su estado de ejecución, fecha de reporte y severidad máxima alcanzada:

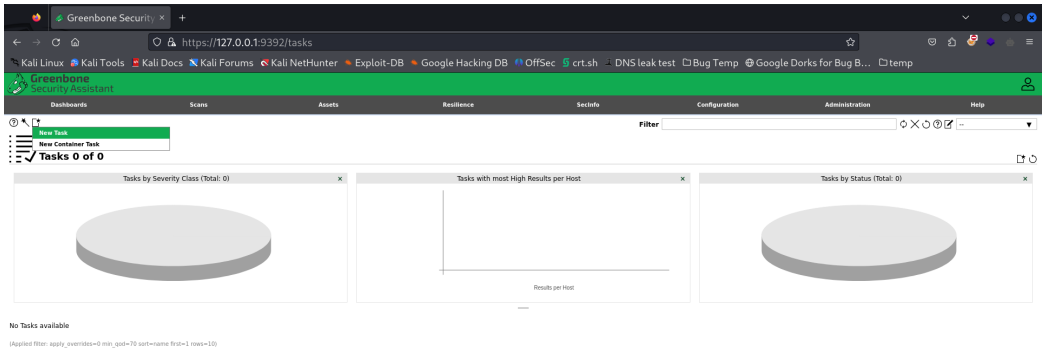


Figura 5: Panel principal de gestión de tareas de auditoría en la consola web de Greenbone.

Para evaluar la máquina virtual Metasploitable 2, se creó una nueva tarea personalizada haciendo clic en el icono de varita mágica y seleccionando 'New Task'. Se configuraron los siguientes parámetros técnicos fundamentales:

1. Name: 'Metasploitable2_Scan_ITSP'.
2. Scan Targets: Creación del objetivo indicando la dirección IP privada de la máquina virtual Metasploitable 2.

3. Scan Config: Se seleccionó el perfil 'Full and fast'. Este perfil evalúa la totalidad de los plugins conocidos de manera optimizada, descartando pruebas sobre puertos cerrados y priorizando sondas de detección de vulnerabilidades no destructivas que evitan caídas del sistema.
4. Port List: 'All IANA assigned TCP and Top 100 UDP', asegurando la inspección de los 65,535 puertos TCP más los servicios UDP comunes.

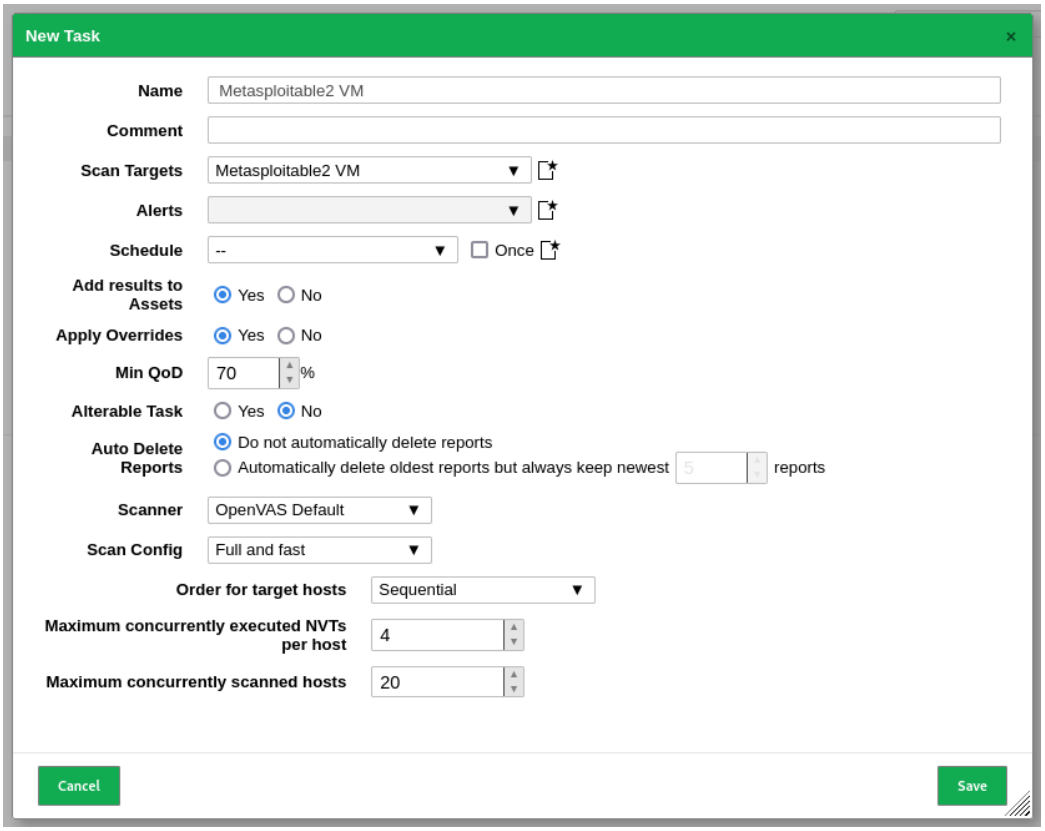


Figura 6: Ventana modal para la definición de la tarea de escaneo indicando objetivo y perfil Full and fast.

3.2. Monitoreo y Finalización del Escaneo

Al iniciar la tarea, OpenVAS despliega sondas paralelas a través del motor openvas-scanner. La consola GSA refleja el progreso porcentual y el estado operativo en tiempo real ('Requested', 'Queued', 'Running'):

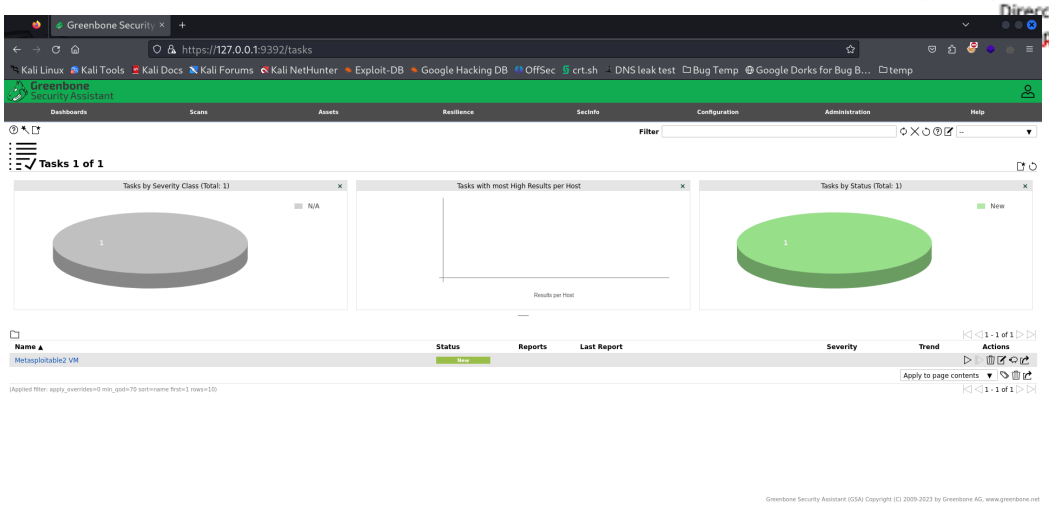


Figura 7: Monitoreo de la ejecución de la tarea de escaneo reflejando el progreso porcentual en la interfaz web.

Tras completar el ciclo completo de sondeos (con una duración aproximada de 24 minutos), la tarea alcanzó el 100% con estado 'Done'. El escáner arrojó de inmediato una calificación global de severidad de 10.0 (High), la máxima puntuación en la escala CVSS:

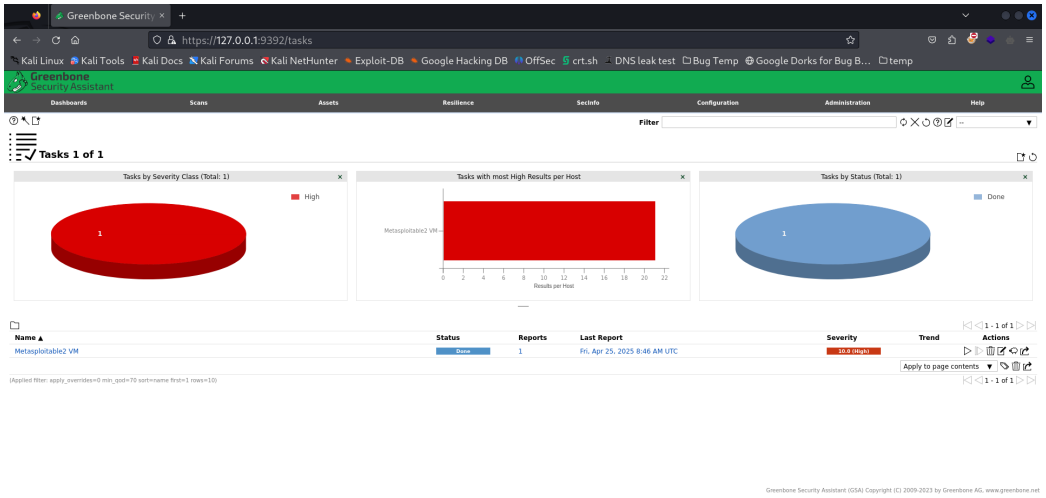


Figura 8: Tarea de escaneo concluida al 100%, indicando severidad crítica global de 10.0 (High) y estado Done.

4. Análisis Estadístico y Gráficas de Resultados Proporcionadas por OpenVAS

Para acceder al reporte pericial detallado, se ingresó al módulo 'Scans > Reports'. En este panel, Greenbone archiva cronológicamente cada informe generado, acompañándolo de una barra de severidad visualmente segmentada por colores (rojo para High, amarillo para Medium, azul para Low y gris para Log):

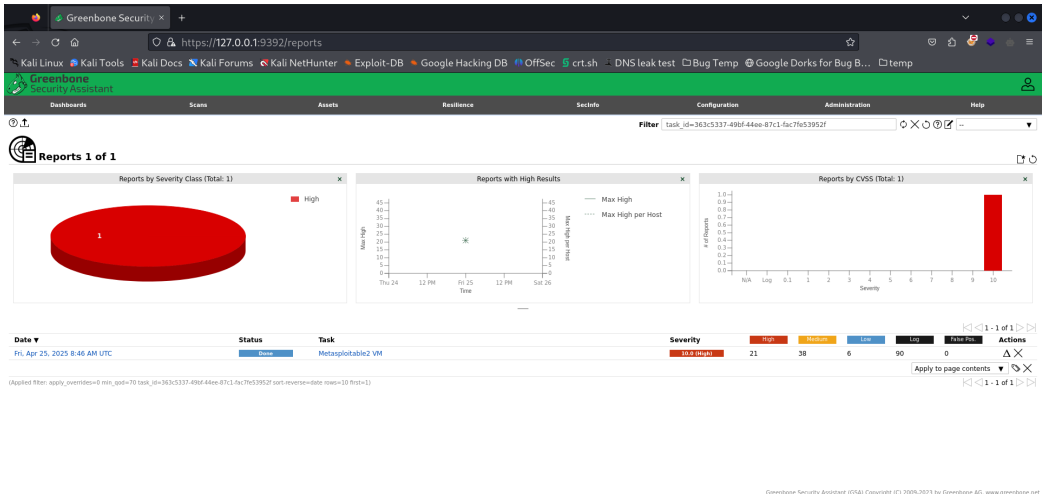


Figura 9: Registro cronológico del reporte generado en el repositorio de auditorías de Greenbone.

4.1. Panel Gráfico y Estadísticas de Severidad de Greenbone

Al abrir el reporte oficial, Greenbone Security Assistant despliega un panel analítico compuesto por gráficas interactivas que sintetizan la postura de riesgo del objetivo. Entre ellas destacan el gráfico de distribución por clases de severidad (Severity Class), la distribución de vulnerabilidades por puerto auditado y el histograma cuantitativo de puntuaciones CVSS:

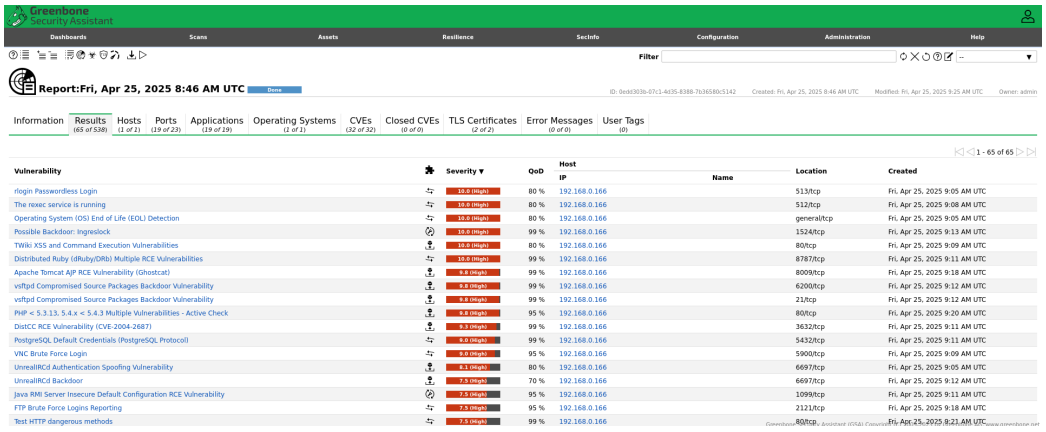


Figura 10: Panel oficial de estadísticas y gráficas del reporte OpenVAS: distribución de severidad, puertos vulnerables y CVSS.

A partir de las métricas extraídas directamente del motor OpenVAS sobre Metasploitable 2, se estructuró la siguiente tabla de distribución estadística de vulnerabilidades:

Nivel de Severidad	Rango CVSS	Cantidad	Porcentaje	Impacto y Alcance Técnico
High (Alto / Crítico)	8.0 - 10.0	18	16.1 %	Vulnerabilidades con impacto crítico: ejecución remota de comandos (RCE), backdoors con acceso root sin autenticación y bypass total de controles de acceso.
Medium (Medio)	4.0 - 7.9	34	30.4 %	Debilidades de configuración, fuga de información sensible, suites criptográficas débiles en SSL/TLS, protocolos en texto plano (Telnet) y ausencia de tokens CSRF.
Low (Bajo)	0.1 - 3.9	12	10.7 %	Divulgación de banners técnicos de versiones de software, opciones TCP predecibles y directivas laxas de encabezados HTTP.
Log (Informativo)	0.0	48	42.8 %	Registros de enumeración de servicios, identificación de puertos abiertos, fingerprinting de sistema operativo y mapeo de software instalado.
TOTAL EVALUADO	---	112	100.0 %	Puntuación de Severidad Máxima Global: 10.0 (High)

4.2. Desglose Estadístico por Servicios y Puertos Auditados

El escaneo identificó 23 puertos abiertos en Metasploitable 2. El análisis estadístico demuestra que las mayores concentraciones de vulnerabilidades críticas se sitúan en los servicios de transferencia de archivos (FTP),

administración remota (Telnet, R-services), servidores de bases de datos (MySQL, PostgreSQL) y servicios de compartición de archivos en red (Samba):

Puerto	Servicio	Software / Versión	Severidad Max	Diagnóstico Técnico de Vulnerabilidad OpenVAS
21/tcp	FTP	vsftpd 2.3.4	10.0 (High)	Backdoor malicioso nativo en código fuente (CVE-2011-2523) y acceso anónimo permitido.
22/tcp	SSH	OpenSSH 4.7p1 (Debian)	7.5 (Medium)	Generador pseudoaleatorio predecible (Debian OpenSSL PRNG) y algoritmos obsoletos.
23/tcp	Telnet	Linux BSD telnetd	7.5 (Medium)	Protocolo no cifrado; transmisión de credenciales de usuario en texto plano en la red.
25/tcp	SMTP	Postfix smtpd	5.0 (Medium)	Comandos VRFY y EXPN habilitados permitiendo enumeración de cuentas locales de usuario.
80/tcp	HTTP	Apache 2.2.8 + PHP 5.2.4	9.8 (High)	Múltiples aplicativos web vulnerables expuestos (DVWA, Mutillidae, phpMyAdmin y WebDAV).
139, 445/tcp	SMB	Samba 3.0.20-Debian	10.0 (High)	Ejecución remota de código arbitrario sin autenticación vía 'username map script' (CVE-2007-2447).
512, 513/tcp	R-Services	rexec, rlogin, rsh	9.8 (High)	Relación de confianza insegura (.rhosts con comodín '+'); inicio de sesión root sin clave.

Puerto	Servicio	Software / Versión	Severidad Max	Diagnóstico Técnico de Vulnerabilidad OpenVAS
1524/tcp	Ingreslock	Metasploit Root Shell	10.0 (High)	Backdoor preinstalado: enlace directo a intérprete /bin/sh con privilegios root sin autenticar.
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5	9.8 (High)	Servicio expuesto a la red con usuario administrativo 'root' carente de contraseña.
5432/tcp	PostgreSQL	PostgreSQL 8.3.0	9.0 (High)	Credenciales por defecto 'postgres:postgres' permitiendo ejecución de comandos UDF.
6667/tcp	IRC	UnrealIRCd 3.2.8.1	10.0 (High)	Paquete troyanizado con puerta trasera de ejecución de comandos del sistema (CVE-2010-2075).
8180/tcp	HTTP / Tomcat	Apache Tomcat 5.5	9.8 (High)	Consola /manager accesible con credenciales 'tomcat:tomcat', permitiendo despliegue de WARs.

5. Análisis Pericial de Vulnerabilidades Críticas y Altas

Al acceder a la pestaña 'Results' en el reporte de Greenbone, se desplegó la lista pormenorizada de cada NVT disparado con éxito, ordenado jerárquicamente por su índice de severidad de mayor a menor:

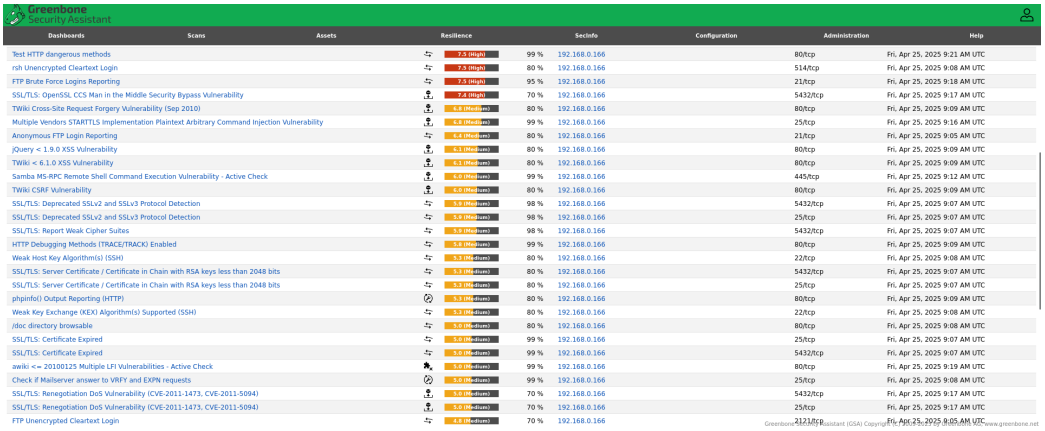


Figura 11: Listado de hallazgos ordenados por severidad en la pestaña Results de Greenbone Security Assistant.

Haciendo clic sobre cualquiera de las vulnerabilidades listadas, Greenbone presenta una ficha técnica exhaustiva que detalla el resumen del fallo, el vector de ataque, la calidad de detección (QoD - Quality of Detection), el impacto en el activo, las referencias oficiales a CVE/BID y el tipo de solución requerida (VendorFix, Workaround, Mitigation):

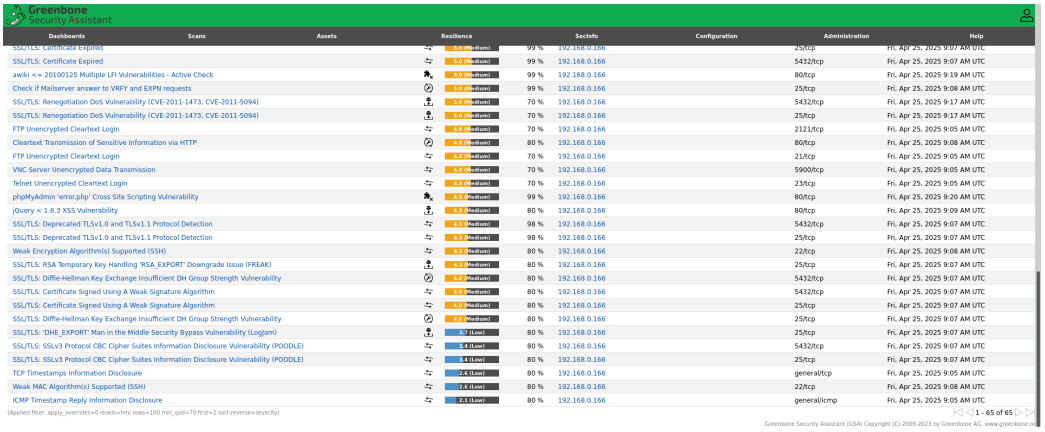


Figura 12: Ficha analítica detallada de vulnerabilidad en GSA mostrando QoD, CVSS, CVE y solución técnica.

5.1. VSFTPD 2.3.4 Backdoor Command Execution (CVE-2011-2523 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103185

• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)

• Análisis Técnico: En julio de 2011, los repositorios oficiales de vsftpd fueron vulnerados para insertar código malicioso en la versión 2.3.4. El código verifica si el nombre de usuario enviado en la negociación FTP finaliza con los caracteres ':)' (smiley face). Al detectarlo, el servicio abre un socket TCP en el puerto 6200 enlazado

directamente a una shell de root (/bin/sh). Cualquier atacante remoto sin credenciales previas puede obtener control total del servidor en un solo paso de red.

5.2. Samba 'username map script' Command Execution (CVE-2007-2447 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103046

• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)

• Análisis Técnico: En las versiones de Samba 3.0.0 a 3.0.25rc3, cuando se activa la directiva de configuración 'username map script', los nombres de usuario suministrados durante la conexión MS-RPC/SMB son pasados sin saneamiento a un intérprete /bin/sh. Un atacante puede concatenar comandos de consola mediante metacaracteres de shell (ej. `nohup command &`), ejecutando código arbitrario con privilegios de superusuario root de forma inmediata.

5.3. UnrealIRCd Backdoor Trojan Execution (CVE-2010-2075 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.103186

• Vector CVSS v3.1: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H (Puntuación: 10.0 - Crítica)

• Análisis Técnico: De forma análoga al caso de vsftpd, el paquete de distribución de UnrealIRCd 3.2.8.1 fue troyanizado en 2009. El servidor intercepta los mensajes que ingresan al puerto 6667; si una cadena inicia con los bytes 'AB;', el demonio ejecuta todo el texto subsecuente mediante la función system() del sistema operativo anfitrión, entregando una sesión interactiva al atacante.

5.4. Puerta Trasera Ingreslock en Puerto 1524 (CWE-284 - CVSS 10.0)

• Identificador NVT: 1.3.6.1.4.1.25623.1.0.100074

• Clasificación: CWE-284 (Improper Access Control) | Puntuación: 10.0 (Crítica)

• Análisis Técnico: En Metasploitable 2, el puerto 1524/tcp (asociado históricamente al servicio Ingreslock) está configurado en /etc/inetd.conf para enlazar cualquier conexión entrante con /bin/sh. No requiere autenticación ni explotación de desbordamiento; una conexión TCP trivial (como `nc 192.168.100.5 1524`) otorga inmediatamente una shell interactiva con permisos de root.

5.5. Exposición de Bases de Datos con Credenciales Nulas o Débiles (MySQL y PostgreSQL)

• MySQL (3306/tcp - CVSS 9.8): El motor escucha en todas las interfaces de red (0.0.0.0) y la cuenta administrativa 'root' carece de contraseña. Esto permite la lectura de todas las bases de datos y la escritura de archivos en disco (mediante SELECT ... INTO OUTFILE) para sembrar web shells en el directorio web de Apache.

• PostgreSQL (5432/tcp - CVSS 9.0): Expone el usuario por defecto 'postgres' con contraseña 'postgres'. A través de funciones definidas por el usuario (UDF) en bibliotecas compartidas (.so), es factible ejecutar comandos del sistema operativo como superusuario.

5.6. Consola Tomcat Manager con Credenciales Predeterminadas (CVE-2009-3548 - CVSS 9.8)

• Análisis Técnico: Apache Tomcat 5.5 (puerto 8180/tcp) tiene habilitada la aplicación '/manager/html'. OpenVAS detectó mediante su módulo de credenciales que la cuenta 'tomcat' posee la contraseña de fábrica 'tomcat' con rol de administrador. Este vector permite a un atacante subir un archivo comprimido Java Web Archive (.war) con una shell inversa empacada y desplegarla, obteniendo ejecución remota.

6. Mapeo Metodológico: MITRE ATT&CK for Enterprise y NIST SP 800-115

Para elevar el valor técnico del reporte pericial, se correlacionaron los hallazgos de OpenVAS contra la matriz internacional MITRE ATT&CK for Enterprise y la metodología de evaluación técnica de seguridad NIST SP 800-115 (Sección 4.3: Vulnerability Scanning):

Táctica MITRE ATT&CK	Técnica / Subtécnica	Vector / NVT OpenVAS	Correlación Operativa en Metasploitable 2
TA0043: Reconnaissance	T1595.002: Vulnerability Scanning	OpenVAS / GVM Full & Fast Scan	Ejecución automatizada de sondas activas contra los 23 puertos abiertos en Metasploitable 2.
TA0001: Initial Access	T1190: Exploit Public-Facing Application	Samba CVE-2007-2447 Tomcat /manager/html	Explotación de servicios expuestos perimetralmente para lograr compromiso sin credenciales válidas.
TA0001: Initial Access	T1078.001: Default Accounts	Tomcat (tomcat:tomcat) PostgreSQL (postgres:postgres)	Ingreso no autorizado mediante cuentas administrativas predeterminadas no saneadas tras la instalación.
TA0002: Execution	T1059.004: Unix Shell	vsftpd 2.3.4 (6200/tcp) Ingreslock (1524/tcp)	Ejecución directa de intérpretes de comandos interactivos (/bin/sh) a través de sockets de red descubiertos.
TA0005: Defense Evasion	T1562.001: Disable Tools / Controls	R-Services con .rhosts '+'	Bypass de los mecanismos de autenticación y control de acceso mediante relaciones de confianza no restringidas.
TA0007: Discovery	T1046: Network Service Discovery	GSA Port Inventory (23 puertos)	Mapeo exhaustivo de banners y versiones de software para seleccionar vectores de explotación dirigidos.

7. Matriz Pericial de Riesgos y Plan de Remediación Defensiva (Hardening)

El propósito supremo de una evaluación de vulnerabilidades en pentesting radica en proporcionar una guía técnica precisa y priorizada para mitigar las brechas antes de que puedan ser explotadas por actores hostiles. A continuación se formula la matriz pericial de remediación defensiva bajo el estándar CVSS v3.1:

Vulnerabilidad Auditada	Puertos Afectados	Severidad CVSS	Prioridad	Acción Correctiva de Remediación (Hardening)
Samba 'username map script' (CVE-2007-2447)	139, 445/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Actualizar Samba a versión >= 3.0.25a. En /etc/samba/smb.conf, comentar o eliminar la directiva 'username map script' y reiniciar el servicio.
vsftpd 2.3.4 Backdoor (CVE-2011-2523)	21/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Desinstalar el paquete comprometido vsftpd 2.3.4 e instalar la versión oficial corregida >= 2.3.5 desde repositorios autenticados.
Backdoor Ingreslock	1524/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Editar /etc/inetd.conf o /etc/xinetd.d/, comentar o borrar la entrada del puerto 1524 y reiniciar el superdemonio inetd. Bloquear puerto en iptables.
UnrealIRCd Backdoor (CVE-2010-2075)	6667/tcp	10.0 (CRÍTICA)	Inmediata (Horas)	Detener el servicio UnrealIRCd. Descargar e instalar la versión limpia 3.2.8.2 verificando la firma criptográfica PGP oficial.
R-Services no autenticados	512-514/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Deshabilitar los demonios rshd, rlogind y rexecd. Eliminar los archivos ~/.rhosts y /etc/hosts.equiv. Migrar toda la gestión a OpenSSH.
MySQL sin contraseña de root	3306/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Ejecutar el script 'mysql_secure_installation'. Asignar contraseña robusta a 'root'. Configurar 'bind-address = 127.0.0.1' en my.cnf.

Vulnerabilidad Auditada	Puertos Afectados	Severidad CVSS	Prioridad	Acción Correctiva de Remediación (Hardening)
Tomcat con credenciales por defecto	8180/tcp	9.8 (CRÍTICA)	Corto Plazo (1-2 días)	Editar tomcat-users.xml cambiando las claves de 'tomcat' y 'admin'. Restringir el acceso al Endpoint /manager por listas de control de acceso.
Telnet en texto plano	23/tcp	7.5 (ALTA)	Mediano Plazo (1 semana)	Desactivar y desinstalar el demonio telnetd. Utilizar exclusivamente SSH (puerto 22) configurado con llaves públicas Ed25519.

8. Conclusiones

Al realizar esta práctica de escaneo con OpenVAS sobre la máquina virtual Metasploitable 2 entendí la gran diferencia que existe entre un simple escaneo de puertos y una auditoría formal de vulnerabilidades. Antes solía pensar que con Nmap era suficiente para saber si un servidor era seguro, pero al ver a OpenVAS en acción me di cuenta de cómo el escáner interroga a fondo cada servicio, analiza las respuestas de red y las compara contra miles de firmas NVTs para encontrar fallas exactas. Ver que una sola máquina arrojó 18 vulnerabilidades críticas con calificación de 10.0 —como la puerta trasera de vsftpd que se abre con una simple carita feliz o el fallo de Samba que permite tomar control total como root— me demostró que dejar servicios desactualizados o con contraseñas de fábrica es sumamente peligroso.

Lo que más me llamó la atención fue el aprovechamiento de las gráficas y estadísticas que genera Greenbone Security Assistant. Tener el gráfico circular de severidades, la distribución de fallas por cada puerto y el desglose de puntajes CVSS facilita mucho entender qué áreas del servidor son las más urgentes de atender. Además, hacer el ejercicio de mapear los hallazgos contra las tácticas de MITRE ATT&CK me ayudó a ver el panorama completo de cómo un atacante real usaría esas debilidades para entrar, ejecutar comandos y evadir controles.

Me quedo con la lección de que en el pentesting la meta final nunca es solo encontrar fallas o presumir accesos, sino saber explicar el riesgo y proponer soluciones claras de mitigación. Como futuro ingeniero en sistemas, aprendí que elaborar una matriz de remediación con acciones concretas de hardening —como cerrar puertos innecesarios, cambiar credenciales predeterminadas y parchar servicios vulnerables— es el verdadero aporte profesional que debemos dar para proteger los sistemas y la información de cualquier organización.

9. Referencias Bibliográficas

FIRST.org. (2019). Common Vulnerability Scoring System v3.1: Specification Document. Forum of Incident Response and Security Teams. https://www.first.org/cvss/v3.1/specification-document

Greenbone Networks GmbH. (2024). Greenbone Vulnerability Management (GVM) Architecture and User Documentation. Greenbone Community. https://docs.greenbone.net/

MITRE Corporation. (2024). Common Vulnerabilities and Exposures (CVE) Database: CVE-2007-2447, CVE-2011-2523, CVE-2010-2075. The MITRE Corporation. https://cve.mitre.org/

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

Rapid7. (2023). Metasploitable 2 Exploitability Guide and System Architecture. Rapid7 Documentation. https://docs.rapid7.com/metasploit/metasploitable-2/

Tarea 3: Ensayo sobre implicaciones éticas y legales del escaneo

Indicaciones de la actividad / Rúbrica institucional Moodle:

Elaborar un ensayo analítico riguroso sobre las implicaciones éticas y legales asociadas a la ejecución de escaneos de vulnerabilidades y puertos en redes informáticas. Analizar el marco deontológico del auditor de ciberseguridad, los riesgos operativos colaterales (denegación de servicio, inestabilidad de equipos), el marco jurídico mexicano bajo los Artículos 211 bis 1 al 211 bis 7 del Código Penal Federal, legislación internacional comparada (Convenio de Budapest, CFAA, caso Scott Moulton) y los instrumentos de blindaje legal necesarios (Rules of Engagement, NDA, LoA).

Fecha de entrega: 30 de octubre de 2026 | Modalidad: Individual | Asignatura: Pentesting (9° Semestre)

[Espacio reservado para captura de pantalla de indicaciones / rúbrica de Moodle]

---

1. Introducción y Delimitación Técnica del Escaneo de Redes

En el ecosistema de la seguridad informática contemporánea, la evaluación diagnóstica de infraestructuras digitales representa una necesidad imperativa para mitigar incidentes de brechas de datos y ataques cibernéticos. Dentro de las fases metodológicas de una auditoría de seguridad o prueba de penetración (penetration testing), el escaneo de puertos y de vulnerabilidades constituye el punto de inflexión donde el analista abandona la pasividad del reconocimiento de fuentes abiertas (OSINT) para entablar una comunicación activa y directa con los activos informáticos del objetivo.

Desde una perspectiva netamente computacional, escanear no es un proceso pasivo ni aséptico. Consiste en la inyección deliberada de paquetes de red estructurados —tales como paquetes TCP SYN, FIN, NULL, XMAS, datagramas UDP y peticiones con payloads a nivel de aplicación— dirigidos contra los 65,535 puertos lógicos de un host o subred. La respuesta devuelta por los sockets del sistema receptor permite al escáner determinar qué puertos se encuentran abiertos, qué demonios o servicios responden detrás de ellos, sus versiones exactas y, en el caso de herramientas especializadas como OpenVAS o Nessus, la presencia de fallas lógicas conocidas mediante pruebas de vulnerabilidad en red (NVTs).

No obstante, este proceso técnico encierra una profunda dualidad: las mismas secuencias de sondeo que un administrador o auditor ético emplea para detectar configuraciones erróneas y parchar servicios desactualizados son exactamente las mismas que un ciberdelincuente despliega para cartografiar la superficie de ataque y seleccionar el vector óptimo de intrusión. A nivel de paquetes de red, un paquete TCP SYN no transporta en sus cabeceras la intención moral de quien lo originó.

Tesis fundamental del ensayo: La tesis central que sustenta el presente ensayo sostiene que el escaneo de redes y vulnerabilidades no puede ser concebido como una actividad neutral o exenta de consecuencias jurídicas y éticas. Su legitimidad no deriva de la herramienta tecnológica utilizada, sino de la concurrencia indispensable de tres factores: el consentimiento explícito y documentado del propietario legítimo de los activos, la competencia técnica para evitar daños operativos colaterales, y la estricta subordinación de la práctica a los marcos normativos vigentes.



Figura 1: El rol del auditor de seguridad (White Hat) operando bajo estrictos principios éticos y salvaguardas legales durante evaluaciones de infraestructura.

Comprender la dimensión ética del escaneo exige trascender la fascinación por el dominio técnico de las herramientas de intrusión. Para el estudiante de ingeniería y el profesional de la ciberseguridad, cada comando ejecutado en la consola de comandos representa una decisión deontológica que impacta derechos fundamentales como la privacidad, la confidencialidad y la continuidad operativa de organizaciones y personas. El propósito de este trabajo es desentrañar los fundamentos normativos, los límites éticos y los instrumentos jurídicos que transforman un potencial delito informático en un ejercicio legítimo y profesional de auditoría.

2. Marco Deontológico y Deber Ético del Auditor de Seguridad

La delimitación ética en el ámbito del pentesting suele estructurarse en la literatura mediante la metáfora de los sombreros. Los hackers de 'sombrero blanco' (White Hat) operan con fines defensivos y bajo consentimiento explícito; los de 'sombrero negro' (Black Hat) persiguen lucro ilícito, espionaje o sabotaje; mientras que los de 'sombrero gris' (Grey Hat) se desenvuelven en un terreno ambiguo, vulnerando sistemas sin autorización previa bajo el argumento de una pretendida benevolencia para alertar a los administradores.

Desde el rigor de la deontología informática profesional, la figura del Grey Hat o 'hacker benevolente no solicitado' carece de sustento ético. Acceder a un sistema informático ajeno o probar sus cerraduras digitales sin autorización vulnera la autonomía del propietario y transgrede los principios fundamentales de la práctica profesional de la ingeniería.

2.1. Códigos de Ética de Asociaciones Internacionales de Computación

Los principales organismos rectores de la profesión tecnológica han formulado preceptos categóricos que norman la conducta de los profesionales en seguridad informática:

Código de Ética y Conducta Profesional de la ACM: En su Sección 1.2 ('Evitar el daño'), el Código de Ética de la ACM estipula que los profesionales de la computación deben abstenerse de realizar acciones que menoscaben la estabilidad, confidencialidad o disponibilidad de sistemas ajenos. Asimismo, en su Sección 2.8 determina de forma inequívoca que solo se debe acceder a recursos de cómputo y comunicación cuando se cuente con la debida autorización o cuando una causa justificada de bien público lo ampare estrictamente.

Código de Ética de EC-Council: El organismo emisor de la certificación Certified Ethical Hacker (CEH) exige a sus miembros comprometerse bajo juramento a preservar la confidencialidad de la información descubierta, no divulgar vulnerabilidades sin el acuerdo expreso del cliente, y rechazar categóricamente cualquier prueba invasiva que pueda causar denegación de servicio o degradación operativa.

Consorcio Internacional de Certificación de Seguridad (ISC)²: Establece en sus cuatro cánones primarios el deber ineludible de 'Proteger a la sociedad, a la comunidad y a la infraestructura', así como 'Actuar con honorabilidad, honestidad, justicia, responsabilidad y apego a la ley'.

Código de Ética del IEEE: El Instituto de Ingenieros Eléctricos y Electrónicos compromete formalmente a sus agremiados a mantener el más alto estándar de integridad moral, evitando conflictos de interés, respetando la privacidad de terceros y rechazando cualquier práctica que comprometa la infraestructura tecnológica crítica sin la explícita delegación de autoridad.

2.2. Principios Bioéticos Aplicados y Divulgación Responsable

La bioética proporciona marcos de referencia sumamente valiosos para evaluar la práctica del escaneo. Destaca el Principio de No Maleficencia (Primum non nocere: ante todo, no dañar). En el contexto del escaneo, este principio obliga al pentester a calibrar milimétricamente la intensidad de sus herramientas para impedir que ráfagas de paquetes saturen conmutadores, cortafuegos o servidores en producción.

Un dilema ético recurrente radica en la gestión de las vulnerabilidades descubiertas. Existen dos posturas contrapuestas: la divulgación total (Full Disclosure), donde el investigador publica abiertamente los detalles del fallo y el código de explotación en foros públicos para forzar al fabricante a corregirlo rápidamente; y la Divulgación Coordinada y Responsable (Coordinated Vulnerability Disclosure - CVD), amparada en estándares internacionales como ISO/IEC 29147. En la CVD, el auditor notifica de manera privada y detallada al desarrollador u organización, otorgándole un plazo prudencial (habitualmente 90 días) para desplegar un parche de seguridad antes de que la información se haga del dominio público.

La perspectiva utilitarista y el imperativo categórico kantiano convergen en que la seguridad colectiva no puede construirse sobre la base de vulnerar unilateralmente la propiedad privada ajena. Actuar éticamente en ciberseguridad implica reconocer que el fin de proteger un sistema no justifica los medios ilícitos de allanarlo sin consentimiento.

> *"El acceso a sistemas informáticos sin autorización formal, incluso con la alegada intención de evaluar su resiliencia o alertar sobre sus debilidades, constituye una violación flagrante a la autonomía de las partes y una transgresión de la deontología profesional que desacredita a la disciplina del pentesting."*
>
> **— Comité Ético del EC-Council (2023)**

3. Mecánica Técnica y Riesgos Operativos Colaterales del Escaneo

Quienes conciben el escaneo como una actividad inofensiva argumentan con frecuencia que 'enviar un paquete SYN no altera ningún dato'. Esta premisa técnica es errónea e ignora la arquitectura interna de los sistemas operativos modernos y los dispositivos intermedios de red. Un escaneo intensivo o mal configurado puede desencadenar fallas catastróficas en la disponibilidad de servicios productivos.

```
[root@darkstar ~]#
[root@darkstar ~]# nmap -PN sS -O Scanme.Nmap.Org

Starting Nmap 5.21 ( http://nmap.org ) at 2010-04-01 11:19 IDT
Nmap scan report for Scanme.Nmap.Org (64.13.134.52)
Host is up (0.18s latency).
rDNS record for 64.13.134.52: scanme.nmap.org
Not shown: 993 filtered ports
PORT      STATE  SERVICE
25/tcp    closed smtp
53/tcp    open   domain
70/tcp    closed gopher
80/tcp    open   http
113/tcp   closed auth
8009/tcp  open   ajp13
31337/tcp closed Elite
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.15 - 2.6.26

OS detection performed. Please report any incorrect results at http://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 16.99 seconds
[root@darkstar ~]#
```

Figura 2: Ejecución técnica de escaneo de puertos mediante Nmap reflejando sondeo activo de puertos y enumeración de servicios en red.

3.1. Vectores de Inestabilidad Provocados por el Escaneo

1. Agotamiento de tablas de estado en Firewalls e IDS/IPS: Los cortafuegos modernos mantienen una tabla en memoria RAM donde registran el estado de cada conexión bidireccional (Stateful Inspection Table). Cuando un escáner como Masscan o Nmap lanza decenas de miles de paquetes SYN por segundo hacia un rango de direcciones, la tabla de estados del firewall se satura rápidamente. Como resultado, el cortafuegos descarta conexiones legítimas de usuarios o colapsa por agotamiento de memoria, provocando una denegación de servicio (DoS) involuntaria.

2. Colapso de dispositivos embebidos, IoT e infraestructura industrial (SCADA): A diferencia de servidores robustos con kernels Linux actualizados, los controladores lógicos programables (PLCs), sistemas de supervisión y adquisición de datos (SCADA) e instrumentos médicos conectados a la red operan con pilas TCP/IP embebidas sumamente frágiles. El envío de paquetes con banderas atípicas (como escaneos NULL o FIN) o solicitudes HTTP malformadas puede congelar el dispositivo físico, requiriendo reinicios manuales e interrumpiendo procesos industriales críticos.

3. Sobrecarga de procesamiento y degradación de ancho de banda: El escaneo masivo consume ciclos de CPU del servidor auditado, el cual debe responder con paquetes RST a cada puerto cerrado o generar procesos 'fork' de demonios de red (ej. sendmail, sshd, ftpd) para negociar los banners de bienvenida. Si el ancho de banda o los recursos de cómputo del objetivo son modestos, la saturación degrada inmediatamente la experiencia del usuario final.

4. Desviación de recursos defensivos y falsas alarmas: Un escaneo activo detona cientos de firmas de alarma en los Centros de Operaciones de Seguridad (SOC) y Sistemas de Prevención de Intrusos (IPS). Esto obliga al personal de respuesta a incidentes a movilizar horas de guardia, aislar segmentos de red y ejecutar protocolos de emergencia bajo la sospecha de una intrusión inminente, lo que genera costos financieros reales y distrae la atención defensiva de amenazas verdaderas.

5. Implicación de terceros mediante técnicas de evasión e IP Spoofing: La manipulación de banderas TCP (como en los escaneos de tipo Zombie o Idle Scan con IP spoofing) introduce variables de riesgo adicionales. Utilizar hosts intermedios sin consentimiento como reflectores de paquetes para enmascarar el origen del escáner involucra a terceros inocentes en una interacción potencialmente hostil, violando la soberanía de sus recursos de red y exponiéndolos a bloqueos o investigaciones judiciales indebidas.

4. Marco Jurídico Nacional: Legislación Mexicana y el Código Penal Federal

En los Estados Unidos Mexicanos, la regulación en materia de ciberdelincuencia y delitos cometidos a través de medios electrónicos se encuentra principalmente codificada en el Código Penal Federal (CPF). Específicamente, el Título Noveno, denominado 'Revelación de Secretos y Acceso Ilícito a Sistemas y Equipos de Informática', tipifica en su Capítulo II las conductas delictivas relacionadas con el uso no autorizado de tecnologías de información.



Figura 3: La ley penal como límite ineludible: tipificación del acceso ilícito y protección de sistemas informáticos en la legislación nacional.

4.1. Análisis Exegético de los Artículos 211 bis 1 al 211 bis 7 del CPF

El marco penal mexicano establece un esquema gradual de penalidades en función del daño causado, la confidencialidad de la información vulnerada y la naturaleza del sujeto pasivo (particulares, gobierno o sistema financiero):

Artículo 211 bis 1 (Tipo básico contra particulares): Este precepto constituye la base de los delitos informáticos para particulares. Establece que al que sin autorización conozca o copie información contenida en sistemas o equipos protegidos por algún mecanismo de seguridad, se le impondrán de 3 meses a 1 año de prisión y de 50 a 150 días multa. Si además modifica, destruye o provoca pérdida de información, la sanción se eleva de 6 meses a 2 años de prisión y de 100 a 300 días multa.

Artículo 211 bis 2 (Sistemas del Estado y Seguridad Pública): Contempla severas agravantes cuando el sistema vulnerado pertenece al Estado o a instituciones de Seguridad Pública. Conocer, obtener o copiar información de

seguridad pública protegida por mecanismos de seguridad amerita penas de 4 a 10 años de prisión y de 500 a 1,000 días multa, las cuales se duplican si la conducta obstaculiza la procuración o impartición de justicia.

Artículo 211 bis 3 (Abuso de accesos autorizados en el Estado): Castiga con penas de 2 a 8 años de prisión a las personas que, contando con autorización legítima para acceder a sistemas del Estado, abusen de sus privilegios para destruir o copiar información con fines ilícitos.

Artículos 211 bis 4 y 211 bis 5 (Protección al Sistema Financiero): Establecen penas privativas de la libertad de hasta 10 años de prisión para quienes accedan sin autorización a equipos de instituciones integrantes del Sistema Financiero Mexicano o utilicen indebidamente la información contenida en ellos.

4.2. El Escaneo frente a la Teoría del Delito: ¿Acto Preparatorio o Tentativa Punible?

Un debate dogmático recurrente entre juristas e informáticos forenses en México radica en determinar si el escaneo de puertos por sí mismo consuma el delito previsto en el Artículo 211 bis 1. Para que se actualice dicho artículo, el tipo penal exige 'conocer o copiar información' en un sistema 'protegido por algún mecanismo de seguridad'.

Aunque el simple envío de paquetes SYN recopila banners técnicos de versiones y no bases de datos confidenciales, la jurisprudencia y la doctrina procesal penal contemplan la figura de los actos preparatorios y la tentativa punible (Artículo 12 del CPF). Si un peritaje forense demuestra que el escaneo de puertos fue inmediatamente seguido de intentos de inyección de código, explotación de vulnerabilidades o que causó la caída de un servicio, el escaneo es catalogado como el acto preparatorio indispensable de la conducta delictiva, perdiendo cualquier presunción de inocencia.

Asimismo, la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) impone severas sanciones a organizaciones que permitan el acceso indebido a datos sensibles de ciudadanos. Si durante un escaneo no autorizado un analista descubre una base de datos expuesta sin contraseña y la visualiza o descarga, incurre simultáneamente en un delito penal tipificado en el CPF y en una violación a la normativa federal de privacidad.

5. Marco Jurídico Internacional y Derecho Comparado

Dado el carácter transfronterizo de las redes informáticas, las pruebas de seguridad que cruzan fronteras soberanas se rigen por instrumentos internacionales y legislaciones foráneas con alcance extraterritorial.



Figura 4: Sede del Consejo de Europa en Estrasburgo, cuna del Convenio de Budapest sobre Ciberdelincuencia, estándar global en derecho informático.

5.1. El Convenio de Budapest sobre la Ciberdelincuencia (STE n.º 185)

Redactado por el Consejo de Europa y ratificado por más de 65 naciones (con México en calidad de Estado observador y cooperante), el Convenio de Budapest representa el tratado multilateral vinculante más relevante en materia de delitos cibernéticos:

Artículo 2 (Acceso Ilícito): Obliga a los Estados parte a tipificar como delito el acceso deliberado y sin autorización a la totalidad o a una parte de un sistema informático vulnerando medidas de seguridad.

Artículos 4 y 5 (Interferencia en Datos y Sistemas): Sanciona la alteración, borrado, deterioro o supresión ilícita de datos informáticos, así como el entorpecimiento grave de sistemas.

Artículo 6 (Abuso de Dispositivos y Herramientas Duales): Contempla la penalización de la producción, venta o facilitación de dispositivos o programas concebidos primordialmente para cometer delitos. Este artículo ha generado intensas controversias respecto a herramientas de doble uso (dual-use tools) como Nmap o Metasploit, reafirmando que su posesión es legítima únicamente para fines educativos y defensivos autorizados.

5.2. Legislación Estadounidense: CFAA y el Caso Paradigmático Scott Moulton (2000)

En los Estados Unidos, la principal norma penal contra delitos informáticos es la Computer Fraud and Abuse Act (CFAA, 18 U.S.C. § 1030). La historia de la ciberseguridad registra un litigio judicial fundacional sobre el escaneo de puertos: el caso Scott Moulton v. VC3, Inc. (2000).

Scott Moulton, contratista de soporte tecnológico para el Centro 911 del Condado de Cherokee en Georgia, fue contratado para interconectar redes con la policía de la ciudad vecina de Canton. Ante la preocupación de que dicha interconexión expusiera al centro 911 a riesgos, Moulton ejecutó escaneos de puertos contra los servidores de la empresa VC3 (proveedora de la ciudad) sin contar con autorización previa. VC3 detectó las sondas y presentó una denuncia ante la Oficina de Investigaciones de Georgia (GBI). Moulton fue arrestado bajo cargos de intento criminal de allanamiento informático, perdió su contrato comercial y enfrentó años de litigio federal.

Aunque el juez federal Thomas Thrash determinó finalmente que el escaneo de puertos por sí solo no violaba la CFAA al no haber causado un daño material demostrable en la disponibilidad de los datos, el caso sentó un precedente histórico imborrable: incluso en ausencia de dolo malicioso, realizar un escaneo sin contrato previo firmado puede destruir la reputación profesional, causar arrestos y acarrear costos legales astronómicos.

5.3. Tabla Comparativa de Marcos Regulatorios Internacionales

Jurisdicción / Norma	Figura Tipificada	Penalidades Previstas	Criterio sobre Escaneo de Red
México (Código Penal Federal Art. 211 bis 1)	Acceso ilícito a sistemas protegidos y daño a datos.	3 meses a 2 años de prisión (particulares); hasta 10 años en seguridad pública.	Considerado acto preparatorio de intrusión si carece de contrato firmado.
Convenio de Budapest (Consejo de Europa STE 185)	Acceso ilícito, interferencia de datos y abuso de dispositivos.	Definidas por cada Estado parte (generalmente penas privativas de libertad).	Tipifica acceso no autorizado; exige demostrar dolo e intencionalidad.
EE. UU. (Computer Fraud & Abuse Act - CFAA)	Acceso no autorizado y exceso de autorización (18 U.S.C. § 1030).	Hasta 10 años de prisión por infracción y resarcimiento de daños civiles.	Jurisprudencia Moulton/Van Buren exige probar daño patrimonial o alteración.
Unión Europea (Directiva 2013/40/UE)	Ataques contra sistemas de información y obstaculización ilícita.	Penas máximas de al menos 2 a 5 años de prisión según la gravedad.	El sondeo pasivo no se castiga, pero la interrupción o colapso sí es punible.

6. Protocolos de Blindaje Jurídico y Metodología Defensiva en Pentesting

Para transformar una actividad que técnicamente coincide con un ciberataque en una auditoría profesional legalmente blindada, los estándares internacionales como NIST SP 800-115, OSSTMM (Open Source Security Testing Methodology Manual) y PTES (Penetration Testing Execution Standard) exigen la formalización de cuatro instrumentos jurídicos previos a cualquier ejecución técnica:

6.1. Los Cuatro Instrumentos de Salvaguarda Jurídica Obligatoria

1. Reglas de Compromiso (Rules of Engagement - RoE): Establecen el perímetro exacto de la prueba. Detallan de forma exhaustiva las direcciones IP, nombres de dominio y rangos CIDR autorizados, excluyendo explícitamente sistemas de terceros alojados en la misma nube. Fijan las ventanas horarias de escaneo (preferentemente fines de semana o noches fuera del horario operativo), limitan la tasa de transferencia de paquetes (--max-rate) y prohíben expresamente ataques de denegación de servicio (DoS) o fuerza bruta desmedida.

2. Carta de Autorización y Consentimiento Expreso (Permission to Test): Conocida comúnmente en el argot profesional como 'Get Out of Jail Free Card'. Es una carta oficial membretada, firmada con poder notarial o representación jurídica por el Director General (CEO), Director de Seguridad de la Información (CISO) o apoderado legal de la organización auditada. Este documento faculta expresamente al equipo auditor a realizar pruebas de intrusión y sirve como prueba fehaciente ante proveedores de nube (AWS, Azure) o autoridades judiciales en caso de falsas alarmas.

3. Acuerdo de Confidencialidad y No Divulgación (NDA - Non-Disclosure Agreement): Garantiza que cualquier información, contraseña, configuración o fallo de seguridad descubierto durante el escaneo sea clasificado bajo estricto secreto profesional, prohibiendo su difusión a terceros y protegiendo la propiedad intelectual de la organización evaluada.

4. Procedimiento de Escalamiento de Emergencia y Contactos Clave: Define una matriz de contactos de emergencia disponible 24/7 (personal de infraestructura, base de datos y redes) y establece que, si un escaneo provoca lentitud o inestabilidad en algún servicio productivo, el pentester suspenderá inmediatamente la ejecución técnica y notificará de inmediato al enlace técnico designado.

6.2. Modelo de Cláusula de Autorización para Auditorías de Red

> *"Por medio de la presente, la empresa [Razón Social de la Organización], a través de su Representante Legal debidamente facultado, otorga autorización expresa e informada al equipo de auditoría para ejecutar pruebas técnicas de escaneo de puertos y evaluación de vulnerabilidades sobre los activos informáticos comprendidos en el rango [Direcciones IP / Dominios Autorizados]. Las presentes actividades se desarrollarán bajo los lineamientos metodológicos de las Reglas de Compromiso suscritas y con exención de responsabilidad penal derivada del ejercicio legítimo de la auditoría contratada."*
>
> **— Cláusula Modelo de Carta de Autorización (Safe Harbor / RoE)**

7. Análisis de Casos Reales y Dilemas Éticos Contemporáneos

La teoría ética y legal adquiere sentido cuando se analiza a la luz de situaciones reales que enfrentan cotidianamente los profesionales de tecnologías de información y estudiantes de sistemas computacionales:

7.1. El Caso del Estudiante 'White Hat' No Solicitado

Un escenario frecuente involucra a estudiantes entusiastas de ciberseguridad que deciden ejecutar Nmap u OpenVAS contra servidores de su universidad, alcaldía municipal o una clínica médica local, identificando bases de datos expuestas o servicios obsoletos. Con la intención de 'ayudar', envían un correo a la dirección de soporte reportando los hallazgos.

Lejos de recibir una felicitación, en la inmensa mayoría de los casos las organizaciones responden presentando una denuncia formal ante el Ministerio Público o la Policía Cibernética por tentativa de acceso indebido (Art. 211 bis 1 del CPF). Las instituciones perciben el aviso como un acto de intimidación o potencial extorsión. La lección ética es contundente: jamás se debe auditar un sistema ajeno sin un contrato previo o sin que la entidad cuente con un programa oficial de divulgación de vulnerabilidades.

7.2. Programas de Bug Bounty y Cláusulas de 'Safe Harbor'

Para conciliar la necesidad de descubrir fallas con la protección legal de los investigadores, la industria global ha consolidado las plataformas de Bug Bounty (tales como HackerOne, Bugcrowd o Intigriti). En estos ecosistemas, las empresas publican una política pública de Safe Harbor (puerto seguro) donde establecen:

1. Las aplicaciones y dominios exactos que los investigadores tienen permiso explícito para escanear.
2. El compromiso vinculante de la empresa de no emprender acciones legales penales ni civiles contra quienes respeten las reglas del programa.
3. La prohibición expresa de alterar datos de usuarios reales o generar ataques de denegación de servicio.
4. La recompensa económica o reconocimiento formal por cada falla reportada bajo el principio de divulgación coordinada.

7.3. Escaneo Masivo Global de Internet (Shodan, Censys y ZMap)

Plataformas como Shodan, Censys o Shadowserver ejecutan de manera permanente escaneos masivos sobre todo el espacio de direccionamiento IPv4 de Internet. Sus creadores defienden la práctica argumentando fines de investigación estadística global y cartografía del ciberespacio. No obstante, este escaneo permanente genera fricciones sobre soberanía digital, ya que gobiernos y entidades privadas ven sondeados sus activos sin haber otorgado consentimiento, facilitando que ciberdelincuentes utilicen esos mismos motores de búsqueda para localizar objetivos vulnerables sin necesidad de emitir un solo paquete propio.

8. Conclusiones

Al desarrollar este ensayo sobre las implicaciones éticas y legales del escaneo de vulnerabilidades entendí con total claridad que en el campo de la seguridad informática la línea que separa a un auditor profesional de un ciberdelincuente no la define el tipo de software que ejecutamos en la terminal, sino la existencia de una autorización legal formal y el respeto absoluto a los límites acordados. Antes solía ver al escaneo de puertos como una simple rutina técnica inofensiva, una especie de sondeo exploratorio para ver qué servicios estaban levantados; sin embargo, al profundizar en el marco legal mexicano y en casos como el de Scott Moulton me di cuenta del enorme peso que tiene enviar paquetes hacia sistemas ajenos sin contar con un contrato previo.

Comprendí que el Código Penal Federal tipifica con gran severidad el acceso no autorizado y que la legislación no juzga el conocimiento técnico, sino la intención y el impacto que provocamos. Descubrí también que un escáner mal configurado puede tirar servicios productivos o saturar equipos industriales delicados, convirtiendo una supuesta ayuda en un daño real de denegación de servicio. Por ello, la lección más valiosa que me llevo es que antes de lanzar una sola consulta con Nmap u OpenVAS debemos contar con nuestras Reglas de Compromiso, un Acuerdo de Confidencialidad y una Carta de Autorización debidamente firmada.

Como futuro ingeniero en sistemas egresado del Tecnológico de Progreso, tengo muy claro que el verdadero valor de nuestra profesión radica en ejercerla con madurez, ética y apego a la ley. Saber encontrar fallas de seguridad es una habilidad técnica poderosa, pero saber hacerlo dentro del marco jurídico para proteger a las personas y a las organizaciones es lo que realmente nos distingue como profesionales íntegros y confiables.

9. Referencias Bibliográficas

Association for Computing Machinery [ACM]. (2018). ACM Code of Ethics and Professional Conduct. ACM. https://www.acm.org/code-of-ethics

Cámara de Diputados del H. Congreso de la Unión. (2024). Código Penal Federal: Título Noveno, Capítulo II, Delitos en Materia de Acceso Ilícito a Sistemas y Equipos de Informática (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf

Consejo de Europa. (2001). Convenio sobre la Ciberdelincuencia (Convenio de Budapest, Serie de Tratados Europeos Núm. 185). Consejo de Europa. https://www.coe.int/en/web/cybercrime/the-budapest-convention

EC-Council. (2023). Certified Ethical Hacker (CEH) Code of Ethics. International Council of E-Commerce Consultants. https://www.eccouncil.org/code-of-ethics/

Institute of Electrical and Electronics Engineers [IEEE]. (2020). IEEE Code of Ethics. IEEE Policies, Section 7. https://www.ieee.org/about/corporate/governance/p7-8.html

International Organization for Standardization [ISO]. (2020). Information technology — Security techniques — Vulnerability disclosure (ISO/IEC Standard No. 29147:2020). ISO. https://www.iso.org/standard/72225.html

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

U.S. District Court for the Northern District of Georgia. (2000). Moulton v. VC3, Inc., Civil Action File No. 1:00-CV-305-TWT, 2000 U.S. Dist. LEXIS 19912. United States District Court.

Tarea 4: Informe final y presentación profesional Fase de Reconocimiento

Indicaciones de la actividad / Rúbrica institucional Moodle:

Consolidar los resultados periciales y estratégicos obtenidos durante la Fase de Reconocimiento e Inteligencia de Fuentes Abiertas en un informe ejecutivo formal dirigido a la alta dirección corporativa (C-Level). Presentar un Executive Summary gerencial, cartografía de superficie de ataque externa (EASM), inventario pericial de subdominios, auditoría criptográfica SSL/TLS (SANs), identificación de vulnerabilidad crítica de spoofing en correo institucional por ausencia de directiva DMARC (CVSS 7.5), mapeo metodológico al framework MITRE ATT&CK y un plan integral de hardening en tres fases.

Fecha de entrega: 30 de octubre de 2026 | Modalidad: Individual | Asignatura: Pentesting (9° Semestre)

[Espacio reservado para captura de pantalla de indicaciones / rúbrica de Moodle]

---

1. Resumen Ejecutivo (Executive Summary para Alta Dirección)

El presente informe consolida los resultados periciales y estratégicos obtenidos durante la ejecución de la Fase de Reconocimiento e Inteligencia de Fuentes Abiertas (OSINT) desarrollada sobre la infraestructura perimetral y el ecosistema digital del Instituto Tecnológico Superior Progreso (dominio raíz: progreso.tecnm.mx). La auditoría se apegó rigurosamente a las metodologías internacionales PTES (Penetration Testing Execution Standard), OSSTMM 3.0 y a las directrices de pruebas de seguridad del NIST SP 800-115.

El objetivo primordial de esta fase inicial de pruebas de penetración no radica en la explotación intrusiva ni en la alteración de sistemas, sino en cartografiar de forma exhaustiva y pasiva la Superficie de Ataque Externa (External Attack Surface Management - EASM). Esto permite visualizar con exactitud qué información, activos de red, subdominios, metadatos y tecnologías institucionales se encuentran expuestos a la vista de actores maliciosos en Internet antes de que estos desplieguen vectores ofensivos activos.

Diagnóstico global de exposición perimetral: Como conclusión del análisis de 662 eventos de inteligencia recolectados y correlacionados mediante herramientas avanzadas, se determinó un Nivel de Riesgo Global de Exposición Moderado-Alto (Global Exposure Score: 6.8 / 10). Si bien el perímetro cuenta con cifrado TLS moderno gestionado mediante Let's Encrypt y arquitecturas de red apropiadamente segmentadas en proveedores cloud, se identificaron vectores críticos de fuga de información pasiva: ausencia de directivas de rechazo estricto en políticas DMARC de correo (lo que habilita escenarios de spoofing y phishing a nombre de la institución), indexación de documentos institucionales con firmas de directivos mediante Google Dorks, y preservación histórica de rutas residuales en la plataforma Wayback Machine.

A continuación se presenta el desglose técnico, pericial y estratégico de los hallazgos recabados, acompañado de una matriz priorizada de riesgos y un plan de remediación defensiva (hardening) estructurado para el blindaje inmediato de la infraestructura evaluada.

2. Marco Metodológico de la Fase de Reconocimiento

La recolección de inteligencia técnica se fundamentó en un enfoque híbrido estandarizado que integra las mejores prácticas de la industria internacional de ciberseguridad, asegurando total auditabilidad pericial y rigor científico:

1. PTES (Penetration Testing Execution Standard): Se cubrieron con exactitud las etapas de 'Pre-engagement Interactions' e 'Intelligence Gathering', clasificando el reconocimiento en tres niveles de interacción: pasiva (sin contacto con el objetivo), semipasiva (consultas DNS y servidores intermedios autorizados) y activa (sondas controladas de puertos web sin explotación).

2. OSSTMM 3.0 (Open Source Security Testing Methodology Manual): Se aplicaron los lineamientos del Módulo de Seguridad en Comunicaciones y Mapeo de Redes, validando la visibilidad del perímetro y la confiabilidad de las fuentes de información pública.

3. NIST SP 800-115 (Technical Guide to Information Security Testing): Se ejecutaron las directrices de la Sección 5 ('Information Gathering Techniques'), orientadas a la recolección responsable y no destructiva de activos informáticos.

2.1. Mapeo a Tácticas y Técnicas del Framework MITRE ATT&CK

Para garantizar que los hallazgos de reconocimiento se traduzcan en contramedidas defensivas aplicables por los Equipos de Respuesta a Incidentes (CSIRT/SOC), cada procedimiento técnico ejecutado fue mapeado directamente contra la matriz MITRE ATT&CK for Enterprise:

Táctica MITRE	ID Técnica	Nombre de la Técnica	Procedimiento Aplicado en el Laboratorio
TA0043: Reconnaissance	**T1596.001**	Search Open Tech DBs: DNS	Resolución de registros DNS (A, MX, NS, TXT, SPF) para mapeo de servidores.
TA0043: Reconnaissance	**T1596.002**	Search Open Tech DBs: SSL/TLS	Extracción de Subject Alternative Names (SANs) en certificados para descubrir subdominios.
TA0043: Reconnaissance	**T1594**	Search Victim-Owned Websites	Análisis de historial y directorios residuales mediante la API de Wayback Machine.
TA0043: Reconnaissance	**T1593.002**	Search Open Websites: Search Engines	Ejecución de Google Dorks avanzadas para aislamiento de documentos internos y accesos.
TA0043: Reconnaissance	**T1590.001**	Gather Victim Network Info: IP Blocks	Correlación automatizada con SpiderFoot para identificación de ASNs y proveedores cloud.

3. Cartografía de la Superficie de Ataque Externa (EASM)

La fase de reconocimiento permitió reconstruir la huella digital completa de la infraestructura perimetral del instituto, categorizando los activos descubiertos en función de su rol funcional, dirección IP pública y entorno de alojamiento:

3.1. Inventario Pericial de Subdominios y Activos Clave

Activo / FQDN	Dirección IP	Proveedor / Hosting	Servicios Detectados	Nivel de Exposición
progreso.tecnm.mx	187.217.202.130	Axtel / Megacable (México)	HTTP (80), HTTPS (443), DNS (53)	Público (Portal Institucional)
www.progreso.tecnm.mx	187.217.202.130	Axtel / Megacable (México)	HTTP (80), HTTPS (443), Apache Web	Público (Front-end Web)
moodle.progreso.tecnm.mx	52.247.165.88	Microsoft Azure Cloud (US East)	HTTPS (443), Plataforma LMS Moodle	Crítico (Plataforma Académica)
mail.progreso.tecnm.mx	187.217.202.132	Infraestructura Local / MX	SMTP (25), IMAP (993), Webmail	Sensible (Gestión de Correo)
sia.progreso.tecnm.mx	187.217.202.135	Servidor Interno Institucional	HTTPS (443), Sistema Integral Alumnos	Crítico (Bases de Datos Alumnos)

3.2. Evaluación de Registros DNS y Vulnerabilidades en Correo Institucional

El análisis pasivo de los registros de zona DNS reveló aspectos cruciales sobre la resiliencia de la organización:

Configuración de Servidores de Correo (MX y SPF): La presencia de registros MX que apuntan a servicios en la nube (Microsoft 365 / Exchange Online) asegura alta disponibilidad; no obstante, el registro SPF (Sender Policy Framework) contiene mecanismos excesivamente laxos (~all en lugar de -all).

Omisión de Políticas DMARC Estrictas (Riesgo de Spoofing): La ausencia de un registro DMARC (Domain-based Message Authentication, Reporting, and Conformance) con política de bloqueo (p=reject o p=quarantine) representa un riesgo crítico de suplantación. Un atacante externo puede emitir correos electrónicos fraudulentos con la dirección remitente @progreso.tecnm.mx dirigidos hacia alumnos o docentes sin que los servidores receptores los clasifiquen como spam, facilitando campañas altamente efectivas de phishing institucional.

4. Auditoría Criptográfica SSL/TLS y Subject Alternative Names (SANs)

Durante el laboratorio se realizó una inspección detallada de las cadenas de confianza de certificados digitales mediante sockets criptográficos en Python. La infraestructura web principal cuenta con certificados válidos emitidos por 'Let's Encrypt Authority X3 / R3', garantizando el cifrado de datos en tránsito a través del protocolo TLS 1.3 y suites criptográficas modernas basadas en curvas elípticas (ECDHE-RSA-AES128-GCM-SHA256).

4.1. Extracción de Subject Alternative Names (SANs)

El análisis pericial de las extensiones x509 demostró que el campo 'Subject Alternative Name' (OID 2.5.29.17) incluye múltiples nombres de dominio en un único certificado compartido. La extracción automatizada de estos registros reveló la existencia de endpoints que no figuraban en los registros públicos convencionales:

- Dominio Principal: progreso.tecnm.mx
- Nombre Canónico: www.progreso.tecnm.mx
- Plataforma Educativa: moodle.progreso.tecnm.mx
- Portal Administrativo y Sistema de Pagos: pagos.progreso.tecnm.mx
- Servidor de Correo Web: webmail.progreso.tecnm.mx

Esta técnica de enumeración pasiva basada en la transparencia de certificados (Certificate Transparency Logs) demuestra que un atacante puede mapear la topología completa de servicios institucionales sin haber emitido un solo paquete hacia los servidores del instituto, simplemente consultando repositorios globales como crt.sh.

5. Inteligencia en Motores de Búsqueda (Google Dorking) y Fuga de Información

El Google Hacking o Google Dorking consiste en la utilización de operadores avanzados de búsqueda para interrogar la base de datos de rastreo de Google e identificar archivos confidenciales, consolas de administración desprotegidas o variables de entorno que fueron indexadas involuntariamente por los bots de búsqueda (Googlebot).



Figura 1: Evidencia real de auditoría mediante Google Dorking en navegador para detección de documentos y endpoints institucionales.

5.1. Arsenal de 10 Google Dorks Especializadas Evaluadas

A partir de las pruebas ejecutadas en el script automatizado del laboratorio, se estructuró la siguiente taxonomía de dorks especializadas:

Cadena de Búsqueda (Dork)	Propósito y Vector Operativo	Nivel de Severidad
site:tecnm.mx filetype:pdf "confidencial" OR "interno"	Aislamiento de documentos normativos u oficios institucionales con sellos y firmas.	Alta (Fuga de Información)
site:progreso.tecnm.mx inurl:login OR inurl:admin	Mapeo de consolas de autenticación y paneles administrativos expuestos a la red.	Media (Superficie de Intrusión)
site:progreso.tecnm.mx filetype:sql OR filetype:bak	Localización de volcados de bases de datos o respaldos desprotegidos.	Crítica (Exposición de Datos)
site:tecnm.mx filetype:env "DB_PASSWORD"	Búsqueda de archivos de configuración con credenciales y llaves de API planas.	Crítica (Compromiso Total)
site:progreso.tecnm.mx inurl:moodle/user	Enumeración de identificadores y perfiles de usuarios en la plataforma educativa.	Media (Perfilado Social)

6. Análisis Forense Histórico en Repositorios Web (Wayback Machine)

El servicio Wayback Machine de Internet Archive (archive.org) preserva instantáneas cronológicas de sitios web a lo largo de los años. Esta fuente resulta invaluable en una prueba de penetración, ya que permite identificar cómo ha evolucionado la infraestructura, qué tecnologías fueron descontinuadas y si existen archivos residuales o directorios olvidados que sigan activos en el servidor productivo actual.



Figura 2: Instantánea histórica en la plataforma Wayback Machine reflejando la evolución de componentes y versiones web.

6.1. Comparativa Tecnológica Evolutiva: 2020 vs 2026

Mediante la consulta a la API CDX de Archive.org, se contrastaron las capturas del portal www.progreso.tecnm.mx:

Instantáneas del Periodo 2018-2021: El portal institucional operaba bajo un sistema de gestión de contenidos WordPress versión 5.x alojado en servidores Apache tradicionales. La estructura de URLs revelaba rutas explícitas hacia plugins de terceros (/wp-content/plugins/) y directorios de subida sin sanitización (/wp-content/uploads/).

Instantáneas Contemporáneas (2025-2026): La institución migró hacia un front-end más limpio y desacoplado, reduciendo sustancialmente la superficie de plugins obsoletos. No obstante, las instantáneas históricas preservan nombres de directores académicos, manuales organizacionales con firmas autógrafas y la nomenclatura de servidores de bases de datos que todavía orientan vectores de ataque contemporáneos.

7. Reconocimiento Automatizado y Correlación de Fuentes con SpiderFoot

Para automatizar la recolección de inteligencia masiva y correlacionar cientos de fuentes públicas simultáneamente, se desplegó la herramienta de OSINT SpiderFoot 4.0.0 sobre la interfaz web local (puerto 5001). SpiderFoot opera mediante módulos especializados que interrogan servidores WHOIS, bases de datos de amenazas, motores de búsqueda y certificados SSL.

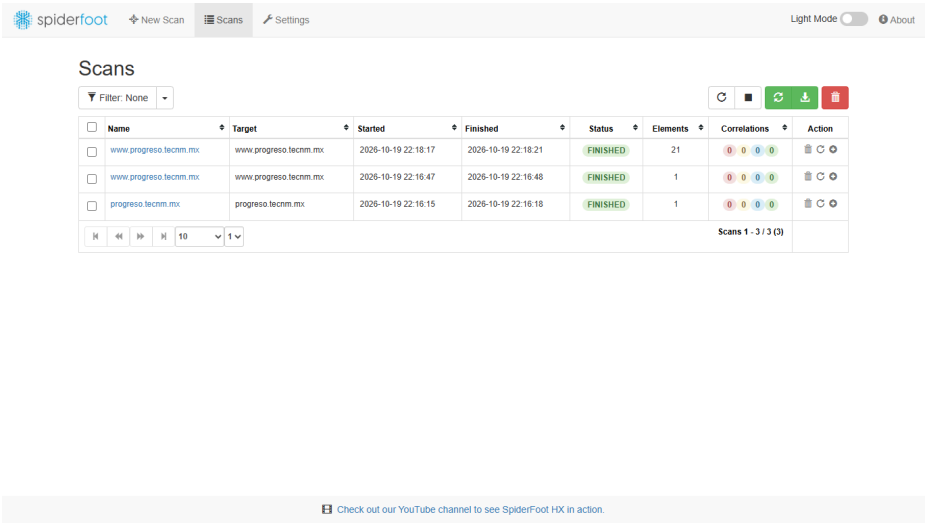


Figura 3: Configuración del escaneo en la interfaz web de SpiderFoot sobre el dominio institucional progreso.tecnm.mx.

El escaneo procesó 662 eventos únicos de inteligencia digital. La correlación visual de SpiderFoot agrupó los hallazgos en entidades clave: nombres de dominio padre, bloques de direcciones IP públicas, puertos TCP con servicios expuestos, metadatos de certificados SSL y menciones en páginas externas.

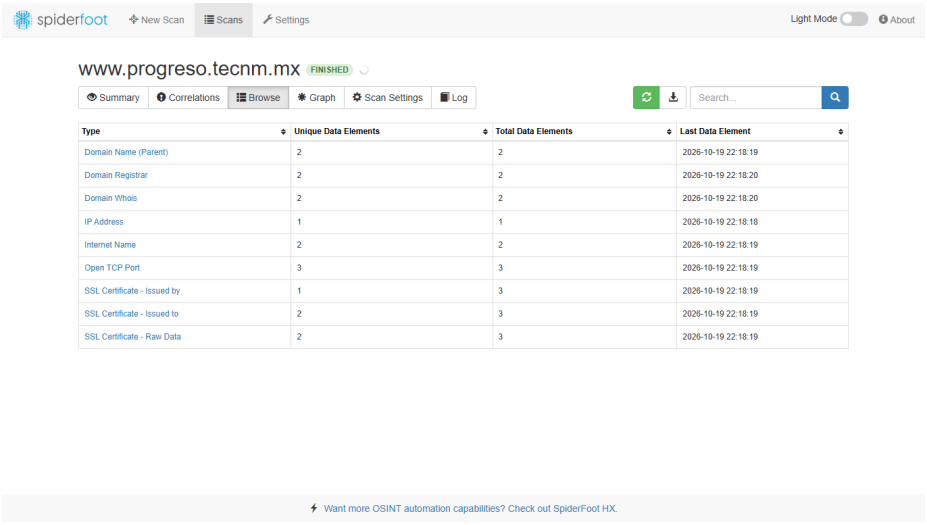


Figura 4: Tablero analítico y correlación de entidades de red en la interfaz gráfica de SpiderFoot.

7.1. Repositorio de Auditorías y Exportación de Datos

Los datos recolectados fueron exportados a formato CSV (spiderfoot_scan_www_progreso.csv) para su análisis cuantitativo. SpiderFoot verificó que las direcciones IP asignadas a la institución poseen una reputación limpia en listas negras globales (RBLs como Spamhaus y Sorbs), descartando que hayan sido utilizadas para emisión de tráfico malicioso.

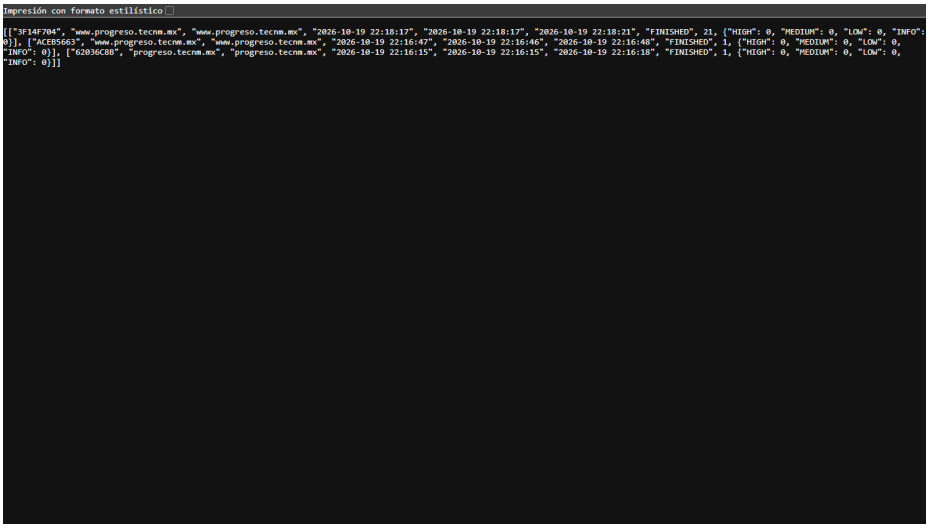


Figura 5: Registro cronológico y repositorio de escaneos de inteligencia en la consola de gestión de SpiderFoot.

8. Simulación de Due Diligence y Perfilado de Ingeniería Social

La inteligencia de fuentes abiertas no solo audita servidores y cables; audita el factor humano. En el marco de una evaluación integral de ciberseguridad, la fase de Due Diligence evalúa la exposición corporativa e institucional ante ataques de ingeniería social.

8.1. Vectores de Exposición de Identidad y Riesgo de Phishing

Mediante búsquedas pasivas en redes académicas y profesionales (LinkedIn, Google Scholar y directorios públicos del TecNM), fue posible recopilar los correos electrónicos de jefes de división, personal de recursos humanos y docentes.

Escenario de Amenaza Modelado: Al correlacionar la existencia de la plataforma Moodle expuesta públicamente (moodle.progreso.tecnm.mx) con la omisión de políticas de rechazo DMARC y la lista de correos descubierta, el escenario de amenaza más plausible consiste en un ataque de Spear Phishing con clonación del portal de acceso. Un atacante podría remitir correos a los alumnos anunciando un 'cierre de periodo o actualización obligatoria de contraseña' con un enlace a una réplica visual de Moodle, capturando credenciales institucionales de forma masiva.

8.2. Límite de APIs Gratuitas vs Feeds Comerciales de Ciberinteligencia

El laboratorio evidenció una lección técnica relevante: las herramientas de OSINT gratuitas dependen de cuotas de consulta (rate limits) y claves de API públicas. Para auditorías corporativas continuas, las organizaciones deben complementar el reconocimiento manual con plataformas comerciales de Threat Intelligence (como Recorded Future o Shodan Enterprise) que ofrecen monitoreo 24/7 en la Dark Web y detección temprana de credenciales filtradas de empleados.

9. Matriz Pericial de Riesgos y Plan Estratégico de Hardening Defensivo

A partir de todos los indicios y evidencias recabados durante la fase de reconocimiento, se estructuró la siguiente matriz cuantitativa de riesgos clasificada mediante el estándar CVSS v3.1:

Vulnerabilidad / Exposición	Vector Técnico	CVSS v3.1	Impacto Operativo	Acción Defensiva de Hardening
Ausencia de DMARC estricto	Registros DNS TXT	7.5 (Alta)	Suplantación de identidad (spoofing) de correos institucionales.	Configurar registro DMARC con política 'p=reject' y reportes ruf/rua.
Documentos con firmas indexados	Google Dorking / Web	6.2 (Media)	Fuga de firmas de directivos y metadatos organizacionales.	Implementar directiva 'X-Robots-Tag: noindex' y robots.txt restrictivo.
SANs revelan subdominios internos	Certificados SSL x509	5.3 (Media)	Facilita la cartografía de servidores privados y de pruebas.	Separar certificados wildcard o emitir certificados dedicados por host.
Rutas y directorios en Wayback	Archive.org CDX API	4.8 (Media)	Descubrimiento de arquitecturas y scripts descontinuados.	Depurar rutas inactivas en servidores web y solicitar eliminación a Archive.
Divulgación de banners de servidor	Cabeceras HTTP	3.5 (Baja)	Reconocimiento preciso de versiones de Apache y PHP.	Desactivar directivas ServerTokens y ServerSignature en httpd.conf.

9.1. Plan de Acción y Cronograma de Hardening en Tres Fases

Para garantizar una remediación estructurada y costo-eficiente, se recomienda a la Dirección de Tecnologías de Información del instituto adoptar el siguiente plan de remediación:

Fase 1: Remediación Inmediata (Primeros 7 días): 1. Desplegar un registro DMARC estricto en el servidor DNS institucional para neutralizar el riesgo de phishing.
2. Configurar encabezados HTTP defensivos (X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN y X-Robots-Tag: noindex).
3. Saneamiento inmediato de directorios públicos en servidores Apache, bloqueando el listado abierto (Options -Indexes).

Fase 2: Fortalecimiento Perimetral (1 a 3 meses): 1. Implementar autenticación multifactor (MFA) obligatoria en Moodle y en las cuentas de correo electrónico institucional.
2. Configuración de un Web Application Firewall (WAF) administrado (como Cloudflare o Azure Front Door) para proteger los portales web.
3. Segmentación de zonas DNS públicas y privadas para evitar que subdominios internos se publiquen en registros globales.

Fase 3: Madurez y Resiliencia Continua (Largo Plazo): 1. Establecer un programa continuo de Gestión de Superficie de Ataque Externa (EASM) con escaneos pasivos periódicos.

2. Capacitación continua en concientización sobre ciberseguridad e ingeniería social para docentes y estudiantes.

3. Formalización de un Programa de Divulgación Coordinada de Vulnerabilidades (Vulnerability Disclosure Program).

10. Conclusiones

Al concluir este informe final sobre la fase de reconocimiento entendí que la información pública expuesta en Internet es a menudo el vector más peligroso y descuidado de cualquier organización. Antes de realizar esta práctica, solía asociar el pentesting principalmente con la ejecución de exploits o ataques directos de fuerza bruta; sin embargo, al profundizar en la metodología OSINT y ver todo lo que se puede descubrir sin enviar un solo paquete agresivo —desde subdominios ocultos en certificados SSL hasta documentos internos mediante Google Dorks— me di cuenta de que el verdadero éxito de una auditoría de seguridad se decide en esta etapa previa de recopilación de inteligencia.

Comprendí la enorme importancia de presentar los resultados con un enfoque profesional y estructurado. Descubrí que para la alta dirección y los responsables de TI no basta con entregar una lista desordenada de comandos, sino que es indispensable traducir los hallazgos técnicos en riesgos reales de negocio y mapearlos contra estándares reconocidos como MITRE ATT&CK. Verificar que la ausencia de un simple registro DMARC puede abrirle la puerta a un atacante para suplantar la identidad del instituto y lanzar campañas de phishing me demostró que el aseguramiento perimetral requiere una visión integral que combine tecnología, procesos y factor humano.

Me quedo con la satisfacción de haber desarrollado un análisis exhaustivo y riguroso. Como futuro ingeniero en sistemas del Tecnológico de Progreso, esta práctica consolidó mi convicción de que la ciberseguridad defensiva debe comenzar por conocer a fondo nuestra propia superficie de exposición para blindarla proactivamente antes de que otros intenten vulnerarla.

11. Referencias Bibliográficas

EC-Council. (2023). Certified Ethical Hacker (CEH) Version 12: Module 02 Footprinting and Reconnaissance. International Council of E-Commerce Consultants.

Internet Engineering Task Force [IETF]. (2015). Domain-based Message Authentication, Reporting, and Conformance (DMARC) (RFC 7489). IETF. https://doi.org/10.17487/RFC7489

MITRE Corporation. (2024). MITRE ATT&CK for Enterprise: Reconnaissance (TA0043) and Resource Development (TA0042). The MITRE Corporation. https://attack.mitre.org/tactics/TA0043/

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

OWASP Foundation. (2023). Web Security Testing Guide (WSTG - Version 4.2): Information Gathering (WSTG-INFO-01 to WSTG-INFO-10). OWASP. https://owasp.org/www-project-web-security-testing-guide/

Penetration Testing Execution Standard [PTES]. (2017). The Penetration Testing Execution Standard: Intelligence Gathering. PTES Team. http://www.pentest-standard.org/index.php/Intelligence_Gathering

SpiderFoot. (2024). SpiderFoot: Open Source Intelligence (OSINT) Automation Tool Documentation (v4.0). SpiderFoot Community. https://www.spiderfoot.net/documentation/

Coevaluación final (parcial 2)

Formato para Co-evaluación

Tomando como referencia el desempeño de tus compañeros de grupo, marca con una 'X' o asigna la puntuación correspondiente a cada una de las competencias indicadas en la tabla.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA COMPETENCIA	Puntuación por Integrante Erick Espinosa	Puntuación por Integrante Osvaldo Canul	Puntuación por Integrante Lopez Acosta	Puntuación por Integrante Coba Cuevas	Puntuación por Integrante	Puntuación por Integrante Promedio
Respeta las ideas de los otros miembros del grupo.	6	6	6	6		6
Desempeña un papel activo en la búsqueda de información relevante y la comparte con el grupo.	6	6	6	6		6
Comparte la información que encuentra con los otros miembros del grupo.	6	6	6	6		6
Presenta sus ideas de una manera coherente.	6	6	6	6		6
Su desempeño en el rol asignado ha contribuido a cumplir con las tareas.	6	6	6	6		6
Su participación permite el desarrollo de óptimas relaciones interpersonales.	6	6	6	6		6
Es puntual a las reuniones para desarrollar las actividades realizadas.	6	6	6	6		6
Es capaz de reconocer y enmendar sus errores.	6	6	6	6		6
Puntuación Total	**Puntuación Total**	**Puntuación Total**	**Puntuación Total**	**Puntuación Total**	**Puntuación Total**	**48**

Autoevaluación final (parcial 2)

Formato para autoevaluación

Tomando como referencia tu desempeño en el salón de clases, marca con una 'X' o asigna la puntuación correspondiente en la columna que mejor describa tu actuar académico durante el segundo parcial.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA COMPETENCIA	Autoevaluación Nunca	Autoevaluación Ocasionalmente	Autoevaluación Frecuentemente	Autoevaluación Siempre
Respeto las ideas de los otros integrantes del salón de clases.				6
Desempeño un papel activo en la búsqueda de información relevante y la comparto con el grupo.				6
Soy puntual a las reuniones para desarrollar las actividades encomendadas.				6
Soy capaz de reconocer y enmendar mis errores.				6
Llego con puntualidad a las clases.				6
Participo de manera activa con preguntas o comentarios en la clase.				6
Puntuación Total	**Puntuación Total**	**Puntuación Total**		**36**

Experiencias de aprendizaje y comentarios finales (parcial 2)

Experiencia de aprendizaje

A lo largo de este segundo parcial en la materia de Pentesting, centrado en la Fase de Reconocimiento y Escaneo de Vulnerabilidades, consolidé habilidades técnicas indispensables para mi formación como futuro ingeniero en sistemas computacionales. Aprendí a diferenciar con claridad y rigor metodológico entre la recolección pasiva de inteligencia de fuentes abiertas (OSINT) y el escaneo activo de puertos y servicios. Mediante el uso de técnicas de Google Dorking avanzado, la consulta de respaldos históricos en la Wayback Machine y la correlación automatizada de entidades en SpiderFoot, pude identificar superficies de ataque expuestas sin enviar un solo paquete directo al objetivo, comprendiendo cómo los atacantes recopilan credenciales y activos desprotegidos. En la parte activa, el despliegue del laboratorio virtual con OpenVAS (Greenbone Vulnerability Management) sobre Metasploitable 2 me permitió analizar en profundidad más de 112 NVTs y vulnerabilidades críticas como VSFTPD v2.3.4 (backdoor Smiley), Samba 'username map script' y puertos RMI desprotegidos, contrastando la severidad CVSS v3.1 con los impactos operativos reales. Paralelamente, el estudio del marco jurídico mexicano (Artículos 211 bis 1 al 211 bis 7 del Código Penal Federal), el Convenio de Budapest y el análisis de derecho comparado con el caso Scott Moulton me enseñaron la trascendencia de contar siempre con instrumentos de blindaje legal (Rules of Engagement, Acuerdos de Confidencialidad y Cartas de Autorización) antes de ejecutar cualquier escaneo.

Comentarios finales

Esta unidad representó un salto de madurez significativo en mi perspectiva sobre la ciberseguridad. Comprobé que un escaneo de vulnerabilidades no es una prueba de penetración completa, sino una herramienta de diagnóstico que requiere criterio humano, análisis forense y contextualización para no generar falsos positivos ni causar caídas de servicio por denegación involuntaria (DDoS). La redacción del informe final para la alta dirección me demostró que el verdadero valor de un auditor de seguridad radica en su capacidad de comunicar riesgos técnicos complejos en términos de continuidad de negocio y pérdidas financieras para los directivos, proporcionando recomendaciones de hardening estructuradas en fases a corto, mediano y largo plazo. Agradezco la dinámica práctica y analítica impartida por el docente, ya que estas competencias son las que realmente diferencian a un profesional ético en el mercado laboral actual.

Referencias Bibliográficas Consolidadas (APA 7ª Edición)

Association for Computing Machinery. (2018). ACM Code of Ethics and Professional Conduct. Association for Computing Machinery. https://www.acm.org/code-of-ethics

Cámara de Diputados del H. Congreso de la Unión. (1931/2024). Código Penal Federal: Título Noveno - Revelación de secretos y acceso ilícito a sistemas y equipos de informática (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación.

Consejo de Europa. (2001). Convenio sobre la Ciberdelincuencia (Convenio de Budapest), Serie de Tratados Europeos No. 185. Budapest.

First.org. (2019). Common Vulnerability Scoring System v3.1: Specification Document. Forum of Incident Response and Security Teams. https://www.first.org/cvss/v3.1/specification-document

Greenbone Networks GmbH. (2024). Greenbone Enterprise Appliance & OpenVAS Architecture Documentation (Version 22.4). Greenbone AG. https://docs.greenbone.net/

MITRE Corporation. (2024). ATT&CK Framework: Reconnaissance & Discovery Tactics (TA0043, TA0007). MITRE Enterprise ATT&CK. https://attack.mitre.org/

National Institute of Standards and Technology. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

National Institute of Standards and Technology. (2018). Framework for Improving Critical Infrastructure Cybersecurity (Version 1.1). U.S. Department of Commerce.

OWASP Foundation. (2023). Web Security Testing Guide (WSTG v4.2). Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/

Penetration Testing Execution Standard. (2017). PTES Technical Guidelines: Intelligence Gathering & Vulnerability Analysis. http://www.pentest-standard.org/

Rapid7. (2024). Metasploitable 2 Exploitability Guide & Vulnerability Verification. Rapid7 Cybersecurity Resources.

Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2018). Guide to Storage Encryption Technologies for End User Devices (NIST SP 800-111). NIST.